

MANUAL PRÁCTICO DE INGENIERÍA DE SEGURIDAD

Protección de la IA empresarial en Amazon Web Services

Una guía práctica para Amazon Bedrock, SageMaker AI, IAM, Macie, Security Hub, OpenAI, Claude, RAG, MCP, agentes, gobernanza y respuesta a incidentes.

Una ruta práctica de aprendizaje



Cada etapa añade capacidad sin eliminar los controles aprendidos anteriormente.

El manual comienza con los fundamentos y avanza progresivamente hacia una operación empresarial segura.

Alberto (AI) Leiva

Versión 1.0 — Julio de 2026

Acerca de este manual

Este manual explica cómo diseñar, construir, proteger, gobernar, probar y operar sistemas de IA empresariales. Comienza con los fundamentos de seguridad, sistemas, identidad, datos, IA y la nube. A continuación, aborda Amazon Web Services y los servicios que se utilizan habitualmente en la IA empresarial. El objetivo es lograr una comprensión práctica: saber qué hace cada componente, dónde cambia la confianza, qué controles son importantes, cómo probarlos y qué evidencia demuestra su eficacia.

RECURSO EDUCATIVO INDEPENDIENTE

Esta publicación no constituye una guía oficial de Microsoft, OpenAI, Anthropic, OWASP, NIST, MITRE, ISO ni de ninguna otra entidad reguladora. Las características del producto, las leyes, los estándares y las licencias están sujetos a cambios. Verifique las decisiones importantes con fuentes oficiales actualizadas y con el asesoramiento de profesionales cualificados.

Práctica segura y autorizada

Utilice los ejercicios únicamente en entornos de su propiedad o para los que tenga autorización explícita para realizar pruebas. Confirme el alcance, las cuentas, los objetivos, los datos, el tráfico previsto, los límites de costos, las comunicaciones, las condiciones de detención y la limpieza antes de realizar las pruebas.

- Utilice datos sintéticos o de bajo riesgo siempre que sea posible.
- No pruebe sistemas públicos, de terceros, de clientes o de producción sin autorización por escrito.
- No intente obtener secretos, información personal ni acceso más allá del objetivo autorizado.
- Deténgase cuando un ejercicio afecte a un sistema, persona o conjunto de datos no previsto.
- Proteja los resultados y las pruebas, ya que pueden contener información confidencial.

REGLA FUNDAMENTAL

La capacidad técnica no otorga autorización.

Cómo usar el manual

Lea los capítulos fundamentales en orden. Los capítulos posteriores pueden servir de referencia, pero cada uno presupone que el lector comprende la identidad, el flujo de datos, la autorización, el riesgo y el ciclo de vida del sistema de IA. Complete el breve laboratorio al final de cada capítulo y guarde la evidencia que genere.

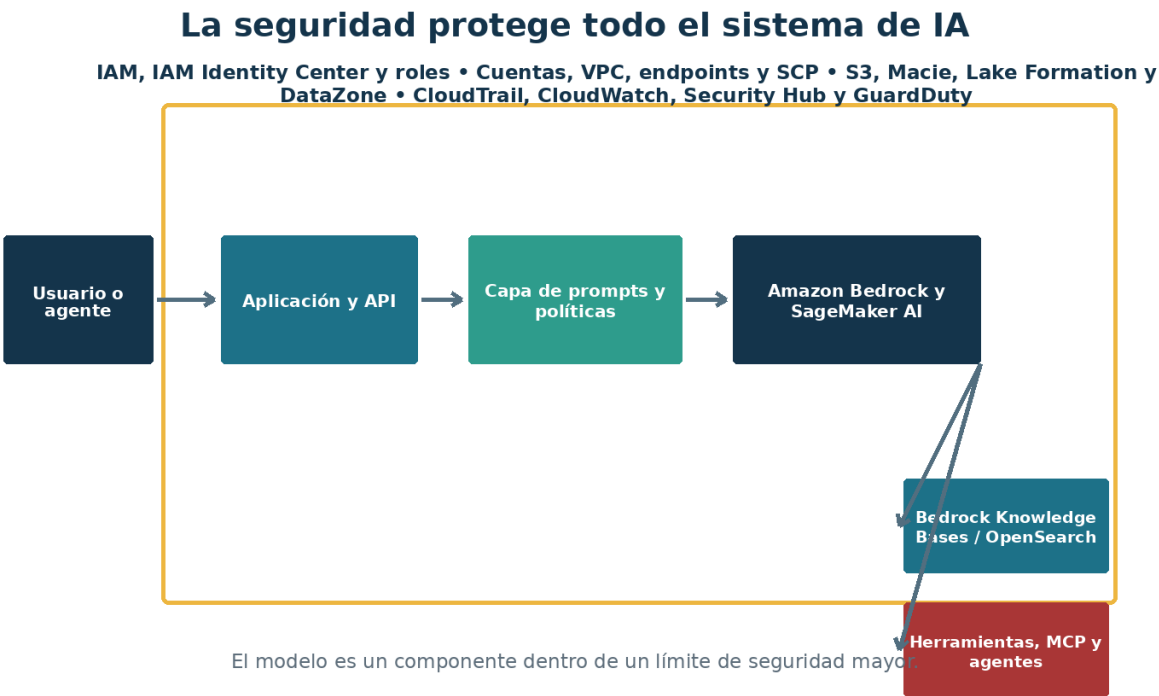


Figura 1. Un modelo opera dentro de un sistema de aplicación, identidad, datos, herramientas y gobernanza.

Tabla de contenidos

Capítulos 1–14	Página	Capítulos 15–28	Página
1. Fundamentos de la ingeniería de seguridad	7	15. Seguridad de la identidad e identidades no humanas	44
2. Sistemas, redes, identidad y fundamentos de datos	10	16. Purview, gobernanza de datos, privacidad y Shadow AI	47
3. Inteligencia artificial, aprendizaje automático y modelos de lenguaje	13	17. Protección de infraestructura, red, secretos y API	50
4. Fundamentos de los servicios en la nube y la IA	16	18. Riesgos de OWASP para LLM, agentes, NHI, API y aplicaciones web	52
5. Cómo funcionan los sistemas de IA empresariales	19	19. Cadena de suministro de IA, desarrollo seguro y LLMOps	55
6. Fundamentos de Azure para la seguridad de la IA	22	20. Evaluación, Red Teaming y Pruebas de Seguridad	57
7. Confianza cero y defensa en profundidad para la IA	24	21. Registro, detección, investigación y respuesta ante incidentes	60
8. Modelado de amenazas en IA y sistemas de agentes	27	22. Fiabilidad, resiliencia, rendimiento y FinOps	63
9. Microsoft Foundry: Proyectos, modelos y controles	30	23. IA responsable, supervisión humana y cambio organizacional	65
10. OpenAI, Claude y las opciones de proveedores de modelos	32	24. Consideraciones legales, reglamentarias, de propiedad intelectual y de registros	68
11. Seguridad de los prompts, el contexto, la memoria y el contenido	34	25. Marcos de referencia: NIST, ISO, MITRE y mapeo de controles.	71
12. Generación aumentada para la recuperación segura	36	26. Creación de un programa de gobernanza y garantía de la IA	73
13. Agentes, herramientas, MCP y comunicación entre agentes	39	27. Laboratorios de ingeniería de seguridad guiada	76
14. Copilotos e IA para la productividad empresarial	41	28. Proyecto final: Agente de conocimiento empresarial seguro	78
Apéndices: listas de verificación, plantillas, glosario y fuentes oficiales.			80

En Microsoft Word, los títulos de los capítulos son seleccionables mediante vínculos.

Hoja de ruta de aprendizaje

La secuencia avanza desde los principios básicos hasta la implementación empresarial completa. Cada parte añade capacidad y responsabilidad.

Parte I — Fundamentos — Comprenda el sistema antes de elegir los controles.

Parte II — Creación de IA en AWS — Cree servicios de IA útiles con límites seguros desde el principio.

Parte III — Protección de los sistemas de IA — Aplicar medidas de protección de identidad, datos, aplicaciones, modelos e infraestructura.

Parte IV — Gobernanza y operaciones — Operar la IA de forma responsable, medir el riesgo y preservar la evidencia.

Parte V — Laboratorios prácticos — Convertir conceptos en prácticas de ingeniería repetibles.

Lo que el lector podrá hacer

- Explique la arquitectura de IA empresarial e identifique sus límites de confianza.
- Utilice conjuntamente los controles de identidad, red, datos, aplicación, modelo y gobernanza.
- Cree flujos de trabajo RAG y de agentes con permisos definidos.
- Aplique las directrices de OWASP LLM, agentic, NHI, API y web.
- Evaluar la calidad, la seguridad, la privacidad, la fiabilidad y el coste.
- Recopilar pruebas, responder a incidentes y vincular los controles a los principales marcos de trabajo.

PARTE I — FUNDAMENTOS

Comprenda el sistema antes de elegir los controles.

COMPRENDER • APLICAR • PROBAR • DEMOSTRAR

Capítulo 1 — Fundamentos de la ingeniería de seguridad

Aprenda el lenguaje, los hábitos y los principios básicos que se utilizan para proteger cualquier sistema antes de aplicarlos a la IA o a AWS.

Lo que protege un ingeniero de seguridad

Un ingeniero de seguridad ayuda a la organización a utilizar la tecnología manteniendo el riesgo dentro de límites aceptables. Su trabajo no consiste en rechazar todos los cambios, sino en comprender los objetivos de la organización, identificar posibles fallos o abusos, implementar medidas de seguridad prácticas y hacer visible el riesgo restante a la persona autorizada para asumirlo.

- **Confidencialidad:** la información solo está disponible para personas y sistemas autorizados.
- **Integridad:** la información, el software y las decisiones son precisos y están protegidos contra cambios no autorizados.
- **Disponibilidad:** los servicios y la información están disponibles cuando se necesitan.
- **Privacidad:** la información personal se maneja de forma legal y respetuosa.
- **Seguridad:** la tecnología no causa daños inaceptables a las personas ni al medio ambiente.
- **Responsabilidad:** las acciones importantes pueden atribuirse a una identidad responsable.

Riesgo explicado en lenguaje sencillo

El riesgo es la posibilidad de que una amenaza explote una vulnerabilidad y cause daño. Comience por el impacto en el activo y el negocio, en lugar de una característica del producto. Describa el escenario con claridad: quién o qué podría actuar, qué vulnerabilidad podría explotarse, qué podría suceder, cuál es la probabilidad y qué controles reducen el riesgo.

- **Activo:** algo valioso que necesita protección
- **Amenaza:** una persona, evento, condición o capacidad que puede causar daño.
- **Vulnerabilidad:** una debilidad que puede ser utilizada o activada.
- **Control:** una medida de seguridad que modifica la probabilidad o el impacto.
- **Riesgo residual:** el riesgo que permanece después de los controles.
- **Responsable del riesgo:** la persona responsable del resultado del negocio.

Tipos de control y evidencia

Los controles preventivos buscan detener un evento. Los controles de detección revelan que ocurrió o está en desarrollo. Los controles de respuesta lo contienen y corrigen. Los controles de recuperación restablecen el funcionamiento seguro. Una política escrita no es prueba de que un control técnico funcione. La evidencia

puede incluir exportaciones de configuración, registros, aprobaciones, tickets, resultados de pruebas, capturas de pantalla, revisión de código y simulacros de incidentes.

- Prefiera controles que sean repetibles y medibles.
- No confíe en la capacitación cuando una medida de seguridad técnica sea viable.
- Pruebe que los controles funcionan en condiciones realistas.
- Excepciones de registro, propietarios, fechas de vencimiento y controles compensatorios
- Conservar las pruebas en un lugar protegido y que permita su inspección.

Un método de ingeniería repetible

Utilice el mismo método básico para cada revisión: comprenda el propósito, haga un inventario de los activos y las dependencias, defina los límites de datos y confianza, identifique las amenazas y los modos de fallo, seleccione los controles, pruébelos, documente el riesgo residual, supervise el funcionamiento y mejore después de un cambio o incidente.

- Haz preguntas sencillas hasta que la arquitectura quede clara.
- Verifique las suposiciones con la configuración y los registros.
- Separar hechos, inferencias y opiniones.
- Aumentar la incertidumbre cuando el impacto potencial sea alto
- Nunca pruebe un sistema sin permiso y sin un alcance acordado.

UN CONTROL QUE EXISTE ÚNICAMENTE EN EL PAPEL

Una política exige que se registre la actividad del administrador, pero el servicio de registro en la nube está deshabilitado en una suscripción. La política describe la intención; la configuración y una prueba exitosa proporcionan evidencia.

Práctica: Redactar una declaración básica de riesgo

- Elija un activo empresarial común, como un repositorio de archivos de clientes.
- Identifique una amenaza, una vulnerabilidad y un impacto creíble.
- Describe el riesgo como una breve declaración de causa y efecto.
- Seleccione un control preventivo, de detección, de respuesta y de recuperación.
- Menciona las pruebas que demuestren que cada control funciona.

Verificación de controles del capítulo

- ☐ Se tienen en cuenta la confidencialidad, la integridad, la disponibilidad, la privacidad, la seguridad y la responsabilidad.

- ☐ Los riesgos se describen como escenarios creíbles.
- ☐ Los controles abarcan la prevención, la detección, la respuesta y la recuperación.
- ☐ Se identifican y conservan las pruebas de control.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 2 — Sistemas, redes, identidad y fundamentos de datos

Comprender los componentes técnicos básicos que los servicios de IA heredan de las aplicaciones convencionales y los sistemas en la nube.

Aplicaciones y API

Una aplicación normalmente cuenta con una interfaz de usuario, lógica de negocio, almacenamiento de datos y conexiones a otros servicios. Las API permiten que los sistemas intercambien solicitudes y resultados. La IA no elimina estas capas; añade un modelo y nuevas formas de entrada, salida e incertidumbre. Las debilidades de las aplicaciones estándar siguen siendo relevantes.

- Validar la entrada y codificar la salida.
- Autenticar a la persona que llama y autorizar la acción solicitada.
- Utilice un transporte seguro como TLS.
- Limitar la velocidad de las solicitudes y controlar el consumo de recursos.
- Gestionar errores sin exponer secretos ni detalles internos
- Mantén las dependencias actualizadas e inventariadas.

Conceptos de red

Cada conexión tiene un origen, un destino, un protocolo, un puerto, una dirección y un propósito. Los endpoints públicos son accesibles desde internet; los endpoints privados mantienen el tráfico dentro de redes controladas. Los firewalls, las pasarelas, los proxies, el DNS, la segmentación y los controles de salida limitan qué sistemas pueden comunicarse.

- Documente los flujos entrantes y salientes
- Negar rutas innecesarias
- Desarrollo, pruebas y producción por separado.
- Inspeccione y registre los puntos de control importantes.
- Proteja con mayor rigor las interfaces administrativas.
- Planifique la gestión de DNS y certificados con anticipación.

Gestión de identidades y accesos

La autenticación verifica la identidad. La autorización determina qué acciones puede realizar dicha identidad. Usuarios humanos, aplicaciones, sistemas automatizados, cuentas de servicio y agentes de IA necesitan identidades. Los roles y permisos deben reflejar las necesidades del puesto o tarea, y el acceso privilegiado debe ser temporal y estar sujeto a revisión.

- Utilice la autenticación multifactor para personas
- Prefiera los tokens de corta duración a las contraseñas o claves almacenadas.
- Aplicar el principio de mínimo privilegio y la separación de funciones.
- Elimine el acceso de inmediato cuando finalice el propósito o la propiedad.
- Revisar identidades privilegiadas e inactivas
- Registrar las decisiones de acceso exitosas y fallidas.

Ciclo de vida de los datos

Los datos se crean o recopilan, clasifican, utilizan, comparten, almacenan, respaldan, conservan, archivan y eliminan. La seguridad debe abarcar todo el ciclo de vida y cada copia derivada. La IA crea derivados adicionales como fragmentos, embeddings, índices, prompts, resultados, conjuntos de datos de evaluación y registros.

- Recoge solo lo necesario
- Fuente del registro, propietario, clasificación, finalidad y uso permitido
- Cifra los datos confidenciales en reposo y en tránsito.
- Restringir el acceso según la finalidad
- Establecer reglas de retención y eliminación
- Confirme que las copias de seguridad, los índices y los datos derivados cumplen con los requisitos de eliminación.

EL MODELO SEGURO DETRÁS DE UNA API INSEGURA

Un endpoint de modelo es privado, pero la API pública de la aplicación acepta cualquier identificador de documento sin verificar si el usuario que ha iniciado sesión tiene permiso para acceder a dicho documento. El modelo está protegido; los datos comerciales no.

Práctica: Rastrear una solicitud web sencilla

- Dibuje un usuario, un navegador, una API de aplicación, un proveedor de identidad, una base de datos y un servicio de registro.
- Etiquete cada conexión de red y límite de confianza.
- Describa la autenticación y la autorización en cada paso.
- Indique dónde existen o se copian datos confidenciales.
- Añada un control y una fuente de evidencia para cada límite.

Verificación de controles del capítulo

- ☐ Los controles de aplicaciones y API siguen formando parte de la seguridad de la IA.
- ☐ Se documentan las rutas de red y los límites de confianza.
- ☐ La autenticación y la autorización se tratan por separado.
- ☐ El ciclo de vida de los datos incluye copias derivadas y eliminación.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 3 — Inteligencia artificial, aprendizaje automático y modelos de lenguaje

Comprender los conceptos esenciales de la IA lo suficientemente bien como para identificar supuestos de seguridad, limitaciones y pruebas significativas.

Inteligencia artificial, aprendizaje automático e inteligencia artificial generativa.

La inteligencia artificial es un término amplio que engloba sistemas que realizan tareas relacionadas con el razonamiento, la percepción, la predicción o el lenguaje. El aprendizaje automático encuentra patrones en los datos en lugar de basarse únicamente en reglas escritas manualmente. La IA generativa produce texto, imágenes, audio, vídeo o código nuevos a partir de patrones aprendidos durante el entrenamiento.

- Un modelo es un sistema matemático aprendido, no una base de datos de hechos garantizados.
- El entrenamiento crea o ajusta un modelo a partir de datos.
- La inferencia utiliza un modelo entrenado para producir un resultado.
- El fine-tuning modifica el comportamiento del modelo con ejemplos adicionales.
- RAG proporciona información externa seleccionada en el momento de la solicitud sin volver a entrenar el modelo.

Cómo un modelo de lenguaje maneja el texto

Un modelo de lenguaje procesa tokens, que son fragmentos de texto en lugar de palabras completas. La ventana de contexto contiene las instrucciones e información disponibles para la respuesta actual. El modelo predice continuaciones útiles basándose en patrones e instrucciones; no verifica la veracidad a menos que el sistema circundante le proporcione fuentes y comprobaciones fiables.

- Prompt: información o instrucciones proporcionadas a un modelo
- System instruction: higher-priority guidance supplied by the application
- Token: una unidad utilizada para procesar entradas y salidas.
- Ventana de contexto: el espacio de trabajo limitado para la solicitud
- Temperatura y ajustes relacionados: controles que pueden influir en la variación de la salida.
- Alucinación: contenido que parece seguro pero que no está respaldado o es incorrecto.

Embeddings y similitud

Un embedding representa el contenido como números, lo que permite al sistema comparar significados o similitudes. Los embeddings admiten búsqueda semántica y RAG. Son datos derivados y pueden revelar

información sobre la fuente. Una base de datos vectorial almacena y busca estas representaciones junto con identificadores y metadatos.

- Proteja las embeddings según la sensibilidad de la fuente.
- Utilice metadatos para preservar la propiedad y los permisos.
- Evaluar si resultados similares son realmente relevantes
- Eliminar elementos incrustados cuando se deba borrar la fuente.
- No considere la similitud semántica como prueba o autorización.

Qué modelos pueden y no pueden hacer

Cuando se conectan a una aplicación, los modelos pueden resumir, clasificar, transformar, redactar, extraer, razonar y llamar a herramientas. Sin embargo, también pueden interpretar erróneamente el contexto, seguir instrucciones maliciosas, exponer información, generar contenido sesgado o inseguro y actuar con excesiva autoridad. La arquitectura circundante debe limitar estas restricciones.

- Utilice criterios de aceptación medibles.
- Verifique las fuentes para obtener respuestas relevantes.
- Mantenga las reglas comerciales deterministas fuera del modelo.
- Requieren juicio humano para decisiones de alto impacto.
- Supervise el comportamiento después de la implementación, ya que el uso y los ataques cambian.

CONFUNDIR FLUIDO CON CORRECTO

Un asistente proporciona una respuesta legal convincente con una cita de apariencia realista. Sin embargo, la cita no existe. El fallo se produce porque el flujo de trabajo premia la fluidez en la respuesta sin recuperación, validación de citas ni revisión humana.

Práctica: Observar la variabilidad del modelo

- Hazle la misma pregunta inofensiva varias veces a una modelo aprobada.
- Registrar las diferencias en los hechos, la redacción, la incertidumbre y las fuentes.
- Añade contexto fiable y repite el ejercicio.
- Defina una prueba que distinga una respuesta fundamentada de una respuesta fluida.
- Enumere las decisiones que nunca deben basarse únicamente en texto generado.

Verificación de controles del capítulo

- ☐ Se distinguen el entrenamiento, la inferencia, el fine-tuning y el RAG.
- ☐ Se entienden los tokens y los límites de contexto.

- ☐ Los datos incrustados se tratan como datos derivados protegidos.
- ☐ La fluidez nunca se considera prueba de corrección.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 4 — Fundamentos de los servicios en la nube y la IA

Antes de empezar a usar AWS, es fundamental comprender cómo los servicios compartidos en la nube, las opciones de implementación y el ciclo de vida de la IA influyen en la responsabilidad de la seguridad.

La seguridad acompaña todo el ciclo de vida de la IA

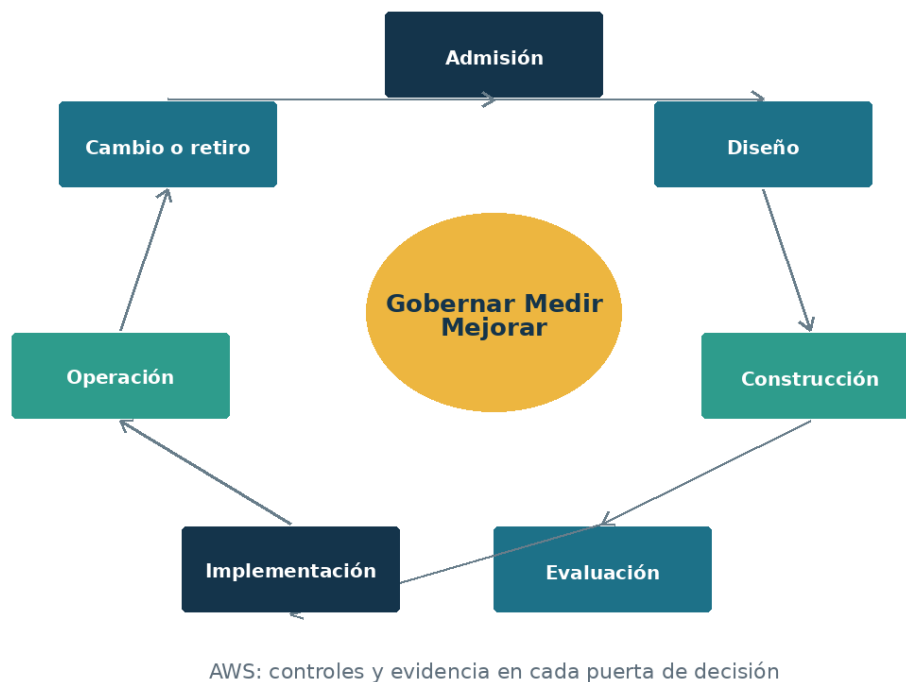


Figura 4. La seguridad y la gobernanza acompañan al sistema desde el ingreso hasta la jubilación.

Modelos de servicio en la nube

Los servicios de infraestructura proporcionan computación, almacenamiento y redes con mayor control por parte del cliente. Los servicios de plataforma gestionan una mayor parte del entorno operativo. Los servicios de software proporcionan una aplicación completa. Las API de IA gestionadas y las plataformas de modelos reducen el trabajo de infraestructura, pero no eliminan la responsabilidad de la identidad, los datos, la configuración, la lógica de la aplicación, el uso legal ni la monitoreo.

- Documentar qué protege el proveedor y qué protege el cliente.
- Revisar la disponibilidad regional y el procesamiento de datos.
- Comprenda el acceso administrativo y de soporte
- Confirme los compromisos de registro, copias de seguridad, recuperación y nivel de servicio.
- Planifica cómo dejar o reemplazar el servicio.

Regiones, tenants y límites de los recursos

Un tenant representa una identidad y un límite administrativo. Las suscripciones y los proyectos organizan los recursos, la facturación, las políticas y el acceso. Las regiones afectan la latencia, la resiliencia, las obligaciones legales y la disponibilidad de funciones. Diseñe estos límites antes de que los datos ingresen a la plataforma.

- Mantén la producción separada de la experimentación.
- Seleccione las regiones en función de sus necesidades comerciales y de datos.
- Evite compartir credenciales entre tenants o entornos.
- Etiqueta los recursos con propietario, propósito, clasificación, entorno y fecha de caducidad.
- Utilice políticas para evitar configuraciones no autorizadas.

El ciclo de vida del sistema de IA

Un sistema de IA pasa por las siguientes etapas: ideación, recepción de datos, diseño, preparación de datos, desarrollo, evaluación, aprobación, implementación, monitoreo, modificación, respuesta a incidentes y retirada. La seguridad y la gobernanza deben estar presentes durante todo el ciclo de vida. Un control añadido únicamente en el momento de la implementación no detecta datos inseguros ni decisiones de diseño tomadas con anterioridad.

- Aprobar el caso de uso y los usos prohibidos
- Evaluar los datos y el riesgo del proveedor.
- Arquitectura del modelo de amenazas y mal uso
- Evaluar la calidad, la seguridad, la privacidad y el costo.
- Supervise y vuelva a realizar la prueba después del cambio.
- Retirar identidades, datos, índices, endpoints y contratos.

Desde la prueba de concepto hasta la producción.

Una prueba de concepto determina si una idea puede funcionar. La producción también debe ser segura, fiable, sostenible, observable, asequible, conforme a las normas y recuperable. Utilice un proceso de lanzamiento basado en evidencia en lugar de permitir que una demostración exitosa se convierta en producción por accidente.

- Establecer fechas de vencimiento para los experimentos.
- Utilice primero datos sintéticos o de bajo riesgo.
- Acceso independiente para desarrollo y producción
- Definir los criterios de aceptación de la producción
- Asignar la responsabilidad de las operaciones y la respuesta a incidentes.

LA DEMOSTRACIÓN QUE SE CONVIRTIÓ SILENCIOSAMENTE EN PRODUCCIÓN

Un asistente piloto obtiene acceso a usuarios reales y datos confidenciales, pero sigue utilizando la clave API del desarrollador y el registro de pruebas. No se toma ninguna decisión formal que registre el cambio, por lo que nunca se establecen los controles de producción ni la propiedad.

- **Práctica: Crear un punto de control del ciclo de vida de la IA**
- Enumere cada etapa del ciclo de vida, desde la idea inicial hasta la jubilación.
- Asigne un responsable a cada etapa.
- Defina las pruebas de seguridad y gobernanza necesarias.
- Seleccione condiciones claras de liberación y parada.
- Agregue un proceso de expiración y limpieza para los experimentos.

Verificación de controles del capítulo

- ☐ La responsabilidad compartida en la nube está documentada.
- ☐ Los límites de tenants, regiones, entornos y recursos son intencionales.
- ☐ La seguridad abarca todo el ciclo de vida de la IA.
- ☐ La producción requiere evidencia y aprobación explícitas.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 5: Cómo funcionan los sistemas de IA empresariales

Construir un modelo mental compartido de un sistema de IA, sus dependencias y los límites que un ingeniero de seguridad debe proteger.

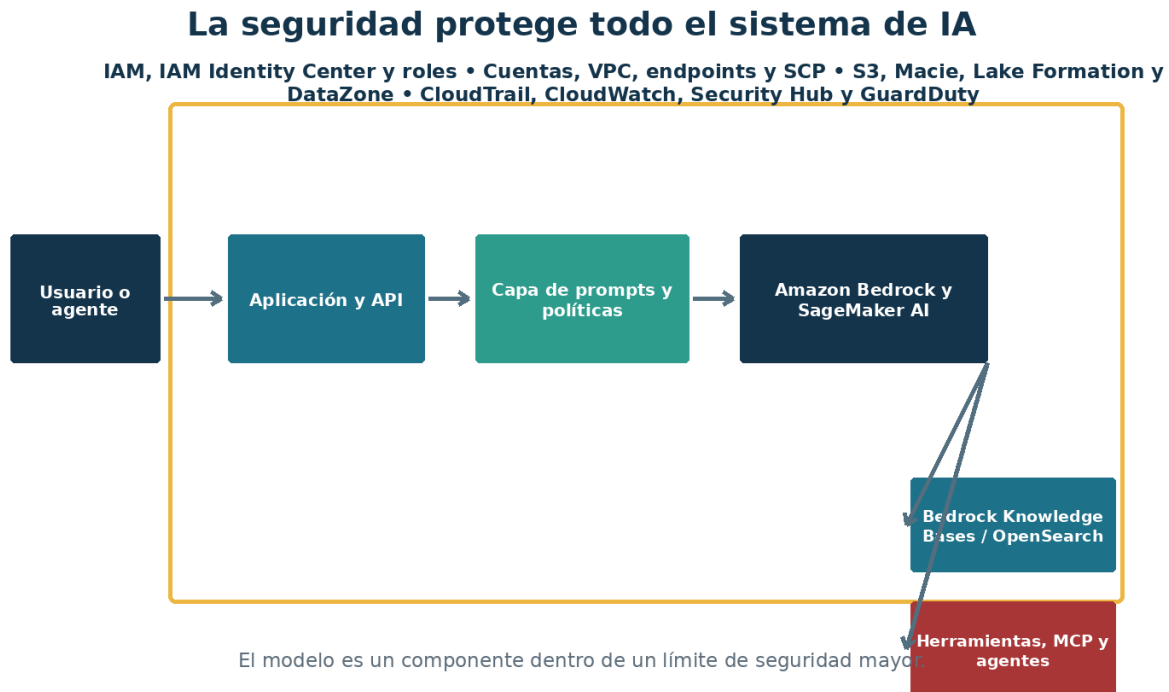


Figura 2. El modelo es solo una parte de la superficie de ataque de la IA empresarial.

El sistema es más grande que el modelo.

Un modelo de lenguaje es solo un componente. Un servicio de producción también incluye una aplicación, identidades, mensajes, fuentes de datos, servicios de recuperación, herramientas, rutas de red, registros, administradores y usuarios. Los fallos de seguridad suelen producirse en la interconexión de estos componentes. Inicie cada revisión dibujando el sistema completo e identificando al responsable de cada parte.

- Configuración del endpoint y del despliegue del modelo
- Aplicación e interfaz de usuario
- Prompts del sistema, plantillas y estado de la conversación
- Almacenes, índices, conectores y documentos fuente de RAG
- Herramientas de agente, servidores MCP, API y sistemas posteriores
- Proveedor de identidad, secretos, controles de red, registro y monitoreo

El comportamiento probabilístico cambia el aseguramiento

El código tradicional sigue una lógica definida. La IA generativa puede producir respuestas diferentes a la misma solicitud, malinterpretar instrucciones o combinar contenido confiable y no confiable. Por lo tanto, las pruebas requieren conjuntos de datos representativos, ejecuciones repetidas, umbrales medibles y monitoreo continuo. Una demostración que funcionó una vez no es prueba de que el sistema sea seguro.

- Pruebas independientes de calidad funcional, seguridad, protección, privacidad y fiabilidad.
- Nombre del modelo de registro, versión del modelo, versión de la solicitud, parámetros y versión del conjunto de datos.
- Pruebe entradas normales, inusuales, hostiles y ambiguas.
- Defina qué debe rechazar, derivar o entregar el sistema a un humano.

Funciones y responsabilidad compartida

Los proveedores de servicios en la nube protegen su plataforma, pero el cliente sigue siendo responsable de la configuración, la identidad, los datos, la lógica de la aplicación, el uso legal y las decisiones operativas. Los proveedores de modelos desconocen el contexto empresarial y el nivel de riesgo aceptable. Asigne responsables para el caso de uso, los datos, el modelo, la seguridad, la privacidad, las operaciones y la supervisión humana.

- El propietario del negocio aprueba el propósito y la tolerancia al riesgo.
- El propietario de los datos aprueba las fuentes y las reglas de acceso.
- El responsable de ingeniería se encarga del mantenimiento de la aplicación y la implementación.
- La seguridad valida la arquitectura, los controles, la monitoreo y la respuesta.
- Los registros de gobernanza incluyen decisiones, evidencia, excepciones y revisiones.

UN ASISTENTE ÚTIL SE CONVIERTE EN UN INCIDENTE DE SEGURIDAD

Un asistente de políticas responde correctamente durante una demostración. En producción, recupera un informe de investigación confidencial porque el índice vectorial no conserva los permisos de los documentos. El modelo funcionó según lo previsto; la arquitectura de autorización falló.

Práctica: Mapear un sistema de IA completo

- Elija un caso de uso de asistente interno de bajo riesgo.
- Dibuje usuarios, aplicaciones, modelos, fuentes de datos, índices, agentes, herramientas, identidades, redes y registros.
- Delimitar los límites de confianza y cada vez que se intercambian datos.
- Indique el nombre del propietario y la documentación requerida para cada componente.

1. Enumere tres maneras en que el sistema podría causar daño sin estar técnicamente comprometido.

Verificación de controles del capítulo

- ☐ El sistema completo, no solo el modelo, está documentado.
- ☐ Los límites de confianza y los flujos de datos son visibles.
- ☐ Se indican los propietarios y los puntos de aprobación.
- ☐ La seguridad, la privacidad, la protección y la fiabilidad se prueban por separado.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 6 — Fundamentos de AWS para la seguridad de la IA

Cree una base de AWS gobernada para que los experimentos de IA no se conviertan en sistemas de producción no gestionados.

Organizar el tenant y las suscripciones

Utilice AWS Organizations, unidades organizativas, cuentas, estándares de nomenclatura, etiquetas, políticas de control de servicios y AWS Config para visibilizar la propiedad y el propósito. Separe la producción del desarrollo y las pruebas. Una única cuenta compartida dificulta la asignación de costos, la revisión del acceso, la contención y la investigación de incidentes.

- Utilice suscripciones dedicadas o límites de recursos estrictos para la producción.
- Propietario de la etiqueta, entorno, clasificación de datos, centro de costos y fecha de vencimiento.
- Aplique políticas de control de servicios, reglas de AWS Config y barreras de protección de Control Tower para las regiones permitidas, redes privadas, cifrado, registro y servicios aprobados.
- Utilice los bloqueos de recursos solo cuando no impidan la respuesta ante emergencias.

La identidad antes que los recursos

Diseñe el acceso antes de implementar los servicios. Utilice grupos de IAM Identity Center, conjuntos de permisos, roles de IAM, credenciales temporales de AWS STS y revisiones de acceso. Evite políticas AdministratorAccess amplias y permisos con comodines. Priorice la federación de identidades y los tokens de corta duración sobre las credenciales almacenadas.

- Separe la administración humana del acceso a la aplicación.
- Utilice el acceso privilegiado justo a tiempo.
- Asignar roles dentro del alcance práctico más reducido.
- Cree cuentas de emergencia y pruebe sus procedimientos.
- Registro de inicios de sesión, cambios de rol, consentimiento y operaciones privilegiadas

Línea base de red y plataforma

Para cargas de trabajo sensibles, utilice puntos de acceso privados, control de salida, segmentación de red, planificación DNS, pasarelas API y registro centralizado. El acceso público debe ser una decisión explícita, no la opción predeterminada que queda tras una prueba de concepto.

- Coloque Amazon API Gateway delante de las API consumidas externamente.
- Restringir los servicios de almacenamiento, búsqueda, modelado y secretos con controles de red.
- Enviar registros de diagnóstico a un espacio de trabajo protegido

- Utilice los hallazgos de AWS Security Hub CSPM, los resultados de AWS Config y las detecciones de GuardDuty como información de entrada, no como el programa de seguridad completo.
- Defina presupuestos, cuotas y alertas antes de realizar pruebas a gran escala.

LA PRUEBA DE CONCEPTO OLVIDADA

Un equipo implementa un endpoint de modelo público con una clave de larga duración y sin alerta de presupuesto. La demostración finaliza, pero el recurso permanece disponible. Meses después, la clave se encuentra en un repositorio y se utiliza para realizar inferencias no autorizadas.

Práctica: Diseñar una landing zone segura de AWS

- Cree un diseño lógico de suscripción y grupos de recursos para desarrollo, pruebas y producción.
- Defina las etiquetas obligatorias, las políticas de control de servicios, las reglas de AWS Config y las barreras de Control Tower.
- Mapee las funciones de administrador, desarrollador, operador, auditor y propietario de la carga de trabajo.
- Defina las rutas de red permitidas y los destinos de registro.
- Escriba una regla de limpieza y caducidad para los experimentos.

Verificación de controles del capítulo

- ☐ Los entornos y las funciones están separados.
- ☐ El acceso utiliza grupos, identidades gestionadas y el principio de mínimo privilegio.
- ☐ La exposición a la red es intencional y está documentada.
- ☐ Existen reglas de registro, presupuestos, cuotas y limpieza antes del despliegue.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 7 — Confianza cero y defensa en profundidad para la IA

Aplique los principios de seguridad habituales a las rutas de datos, herramientas, memoria y acciones autónomas específicas de la IA.

Defensa en profundidad para IA empresarial



Figura 3. La seguridad de la IA depende de varias capas independientes.

Verificar explícitamente

Cada usuario, carga de trabajo, agente, herramienta y solicitud de datos requiere una identidad verificada y una autorización. No considere una solicitud como confiable solo porque provenga de una interfaz de chat o porque la haya generado un agente. El modelo no es un motor de autorización.

- Autenticarse en cada límite del servicio.
- Autorizar la acción y los datos solicitados, no solo el acceso a la aplicación.
- Vuelva a comprobar la autorización cuando un agente llame a una herramienta.
- Conservar el contexto del usuario sin otorgar al agente el privilegio completo del usuario.
- Registrar actor, sujeto, recurso, acción, decisión y resultado.

Aplicar el privilegio mínimo y asumir una posible vulneración

Limite el alcance de una inyección de código maliciosa, un token robado, un conector comprometido o un agente defectuoso. Los permisos restrictivos, los límites de transacciones, el aislamiento de procesos (sandbox), la aprobación humana y la separación de entornos reducen el impacto.

- Proporcione a los agentes herramientas específicas para cada tarea en lugar de interfaces de línea de comandos generales.
- Utilice el acceso de solo lectura a menos que sea necesario realizar modificaciones.
- Establezca límites de gasto, consulta, archivo y transacción.
- Se requiere aprobación para cambios de eliminación, pago, identidad, aspectos legales, seguridad y producción.
- Cree un método rápido para deshabilitar un agente, una identidad, un conector o una implementación de modelo.

Aplicar controles por capas

Ningún filtro por sí solo puede garantizar la seguridad de un sistema de IA. Es necesario combinar controles de identidad, red, datos, aplicación, modelo, monitoreo y gobernanza. Los filtros de contenido reducen ciertos resultados perjudiciales, pero no sustituyen la autorización, la codificación segura ni la supervisión humana.

- Prevenir con arquitectura y mínimo privilegio
- Detectar mediante registros, señales de comportamiento, evaluaciones y alertas.
- Responda con planes de acción y vías de revocación ensayadas.
- Recupérese con servicios de reversión, copias de seguridad y respaldo seguros y probados.

UN MODELO SEGURO CON UNA HERRAMIENTA INSEGURA

Un agente dispone de un sistema de avisos probado, pero también de una herramienta capaz de eliminar recursos en la nube. Un documento malicioso le ordena ejecutar dicha herramienta. La defensa adecuada no reside en una frase más contundente en el aviso, sino en la restricción de permisos, la separación de entradas, la aprobación y el control de transacciones.

Práctica: Crear un mapa de controles de defensa en profundidad

- Seleccione un agente que pueda buscar documentos y abrir un ticket de servicio.
- Enumere los controles preventivos, de detección, de respuesta y de recuperación.
- Indique qué medidas de control seguirán siendo efectivas si fallan las defensas inmediatas.
- Identificar el radio máximo de explosión creíble.
- Añade un control que reduzca ese radio de explosión al menos a la mitad.

Verificación de controles del capítulo

- ☐ El modelo nunca se utiliza como instrumento para tomar decisiones de autorización.
- ☐ Los permisos del agente y de la herramienta son específicos de cada tarea.
- ☐ Las acciones con consecuencias importantes requieren controles más estrictos.
- ☐ Se representan la prevención, la detección, la respuesta y la recuperación.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 8 — Modelado de amenazas en IA y sistemas de agentes

Identifique las debilidades del diseño antes de la implementación mediante la modelización de los activos, los flujos de datos, los límites de confianza, el uso indebido y los fallos.

Comenzar con los activos y los daños

Proteja más que la confidencialidad. Los activos importantes de la IA incluyen instrucciones, acceso al modelo, embeddings, integridad del código fuente, confianza del usuario, calidad de las decisiones, permisos de las herramientas, presupuesto, seguridad y el registro de auditoría. Describa el daño que podría ocurrir si cada activo se divulga, modifica, destruye o utiliza indebidamente.

- Datos sensibles y regulados
- Mensajes del sistema, políticas y conocimiento propietario
- Integridad del modelo, del conjunto de datos, de la embedding y del índice
- Credenciales del agente y autoridad delegada
- Corrección, disponibilidad, costo, reputación y seguridad humana

Mapear los flujos reales de datos y control

Muestre dónde se generan los prompts, dónde se integra el contenido recuperado en el contexto, dónde se almacena la memoria y dónde se invocan las herramientas. Marque el contenido externo como no confiable, incluso si parece texto normal. Documente las rutas administrativas y de mantenimiento con la misma precisión que las rutas de usuario.

- Flujo de usuario a aplicación y de aplicación a modelo
- Ingestión, segmentación, embedding, indexación, recuperación y eliminación.
- Llamadas de agente a herramienta, MCP, API y de agente a agente
- Rutas de telemetría, evaluación, soporte y respuesta a incidentes
- Dependencias de modelos, conectores, paquetes y SaaS de terceros

Modelar conjuntamente el uso indebido y los fallos

Una revisión segura incluye ataques maliciosos, errores comunes, limitaciones del modelo, combinaciones inesperadas y fallos operativos. Utilice STRIDE para componentes convencionales, OWASP para riesgos de aplicaciones, MITRE ATLAS para técnicas de IA adversaria y escenarios de daño estructurados para personas y procesos de negocio.

- Inyección de prompts, contaminación, extracción, evasión y exfiltración.
- Autonomía excesiva y comportamiento confuso del agente.

- Alucinaciones, sesgos, dependencia excesiva de la automatización y consejos inseguros.
- Interrupción del servicio, agotamiento de cuotas, costos descontrolados, conocimiento obsoleto y retiro de modelos.
- Abuso por parte de personas internas, administradores, proveedores y cuentas comprometidas

LÍMITE DE CONFIANZA OCULTO DENTRO DE UN PDF

Un flujo de trabajo de selección de currículos extrae texto de archivos PDF cargados. El diagrama de arquitectura muestra el servicio de carga, pero no el punto donde el texto del documento se convierte en instrucciones del modelo. Un atacante inserta instrucciones ocultas en un PDF y modifica el comportamiento del agente.

Práctica: Modelar una amenaza en un asistente de documentos

- Identificar activos, actores, puntos de entrada, dependencias y límites de confianza.
- Escriba diez escenarios de mal uso o fallo.
- Estimar la probabilidad y el impacto utilizando el método de la organización.
- Asigne controles preventivos y de detección a los riesgos más elevados.
- Registre el riesgo residual, el propietario, la fecha de vencimiento y la autoridad de aceptación.

Verificación de controles del capítulo

- ☐ Se incluyen activos no tradicionales como la confianza, la exactitud y el costo.
- ☐ El contenido recuperado y las llamadas a herramientas aparecen como límites de confianza.
- ☐ Se modelan tanto los fallos maliciosos como los accidentales.
- ☐ El riesgo residual tiene una autoridad de aceptación designada.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

PARTE II — CREACIÓN DE IA EN AWS

Cree servicios de IA útiles con límites de seguridad desde el principio.

COMPRENDER • APLICAR • PROBAR • DEMOSTRAR

Capítulo 9 — Amazon Bedrock y SageMaker AI: proyectos, modelos y controles

Utilice Amazon Bedrock y SageMaker AI como un entorno de ingeniería controlado, en lugar de un espacio aislado para la creación de modelos.

Comprender la función de la plataforma

Amazon Bedrock ofrece acceso gobernado a modelos fundacionales, Guardrails, Knowledge Bases, Agents, evaluación y observabilidad; SageMaker AI admite creación, personalización, implementación y MLOps más amplios. Un proyecto debe tener un propósito comercial definido, clasificación de datos, responsable, entorno, presupuesto y ruta de lanzamiento. El éxito en el entorno de pruebas (Playground) marca el inicio de la ingeniería, no la aprobación para producción.

- Cree proyectos y conexiones independientes para cada entorno.
- Limitar quién puede implementar modelos o cambiar conexiones
- Utilice identidades administradas y conexiones aprobadas.
- Registro de la región, el proveedor, el tipo de implementación, la cuota y la configuración del filtro de contenido.
- Exportar comprobantes de evaluaciones y aprobaciones

Seleccione los modelos deliberadamente

Seleccione un modelo en función del caso de uso y la evidencia. Un modelo más grande o más nuevo no es automáticamente más seguro ni más apropiado. Compare la calidad, la latencia, el costo, los límites de contexto, la compatibilidad con herramientas, el manejo de datos, la región, los términos contractuales, el comportamiento de seguridad y la portabilidad.

- Cree un conjunto de datos de evaluación representativo antes de la selección.
- Pruebe al menos una alternativa razonable.
- Limitaciones del modelo de documento y del proveedor
- Confirmar los términos de procesamiento y retención de datos.
- Planifique los cambios de versión, la retirada y la reversión.

Separar la experimentación de la publicación

Utilice un proceso de lanzamiento que requiera revisión de la arquitectura, modelo de amenazas, aprobación de datos, revisión de identidades, resultados de la evaluación, hallazgos del equipo rojo, monitoreo, manual de incidentes y aceptación por parte del negocio. Los cambios en producción deben ser rastreables y reversibles.

- Prompts de versión, código, implementaciones de modelos, conjuntos de datos y configuraciones de evaluación.
- Require peer review for system instructions and tool definitions
- Proteja las conexiones y los secretos de producción.
- Vuelva a realizar la prueba después de cambios en el modelo, la solicitud, la recuperación, la herramienta o la política.

EL MODELO CAMBIA, PERO LA APROBACIÓN NO

Un equipo reemplaza un modelo de implementación para mejorar la calidad. La nueva versión se comporta de manera diferente con los rechazos y las llamadas a herramientas, pero no se ejecutan pruebas de regresión porque el código de la aplicación no ha cambiado.

Práctica: Crear un registro de lanzamiento de Bedrock o SageMaker AI

- Defina un proyecto de ejemplo, su propietario, propósito, clasificación de datos y entorno.
- Comparar dos modelos candidatos utilizando cinco criterios de calidad y cinco criterios de riesgo.
- Cree una lista de verificación para la liberación y una lista de evidencia requerida.
- Defina los desencadenantes de la reversión y el modelo de reserva aprobado.
- Registre los componentes exactos que requieren una nueva prueba después del cambio.

Verificación de controles del capítulo

- ☐ Cada proyecto tiene un propietario, un propósito, una clasificación y un presupuesto.
- ☐ La selección del modelo está respaldada por evidencia de evaluación.
- ☐ Las tareas de experimentación y producción están separadas.
- ☐ Los cambios se versionan, se vuelven a probar, se aprueban y son reversibles.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 10 — OpenAI, Claude y las opciones de proveedores de modelos

Comprenda las opciones de implementación y evite confundir una aplicación para consumidores con un servicio API empresarial.

Distinguir los servicios

ChatGPT es una aplicación y un espacio de trabajo de OpenAI. La API de OpenAI es una plataforma para desarrolladores. Los modelos de OpenAI pueden consumirse mediante la API directa de OpenAI, mientras que las rutas de modelos en AWS suelen utilizar Amazon Bedrock o SageMaker AI bajo controles de AWS. Claude se puede obtener directamente de Anthropic o a través de plataformas en la nube compatibles, incluido Amazon Bedrock, cuando esté disponible. El modelo de seguridad, facturación, identidad, retención, región y características puede variar según la vía de acceso.

- Documentar la parte contratante y el procesador de datos.
- Confirme si los datos del cliente se conservan o se utilizan para mejorar el servicio.
- Verificar la disponibilidad de la región y las funciones.
- Utilice espacios de trabajo empresariales y API para datos empresariales.
- No asuma que una suscripción personal tiene controles empresariales.

Crear una evaluación del proveedor

Evalúe a los proveedores y las rutas de implementación utilizando las mismas preguntas de control. Revise las certificaciones de seguridad, el flujo de datos, los subprocesadores, la notificación de incidentes, el ciclo de vida del modelo, la supervisión de abusos, los controles administrativos, el registro de eventos, la disponibilidad, la portabilidad y el soporte de salida.

- Registro de clasificaciones de datos permitidas para cada ruta
- Revisar las opciones de autenticación y gestión de claves
- Confirmar que los registros estén disponibles para el cliente.
- Comprender los procesos de filtrado de contenido y apelación.
- Pruebe el efecto de los cambios de proveedor en el comportamiento de la aplicación.

Diseño para una portabilidad controlada

Evite vincular la autorización crítica o las reglas de negocio al comportamiento de un solo modelo. Utilice una capa de control de aplicaciones, conjuntos de datos de evaluación normalizados, adaptadores específicos del proveedor y mecanismos de respaldo documentados. La portabilidad tiene un coste, pero unos límites controlados reducen el riesgo de migraciones de emergencia.

- Mantener la aplicación de las políticas fuera del modelo.

- Mantener casos de prueba independientes del proveedor
- Separe los prompts del código fuente siempre que sea posible.
- Realizar un seguimiento de las características y limitaciones específicas del proveedor.
- Pruebas de respaldo para calidad, seguridad, latencia y costo.

LOS DATOS COMERCIALES SE INTRODUCEN EN UNA CUENTA PERSONAL

Un empleado utiliza una suscripción personal de IA para resumir un contrato con un cliente porque la interfaz es idéntica a la del espacio de trabajo empresarial aprobado. El control que falta no reside en la inteligencia del usuario, sino en políticas claras, análisis técnico, capacitación y una alternativa aprobada y sencilla.

Práctica: Comparar rutas de despliegue

- Compare la API directa de OpenAI, una ruta de modelos de Amazon Bedrock, la API directa de Claude y Claude a través de Amazon Bedrock.
- Registrar las diferencias en cuanto a identidad, red, registro de actividad, retención, región, facturación y contrato.
- Defina las clasificaciones de datos permitidas para cada una.
- Elija una ruta para un asistente interno regulado y explique la decisión.

Verificación de controles del capítulo

- ☐ Las aplicaciones de chat y las API para desarrolladores se distinguen claramente.
- ☐ Se documenta el riesgo del proveedor y de la ruta de despliegue.
- ☐ Las clasificaciones de datos permitidas son explícitas.
- ☐ El mecanismo de reserva no elude los controles de seguridad ni de gobernanza.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 11 — Prompt, contexto, memoria y seguridad del contenido

Trate los prompts y el contexto como componentes controlados de la aplicación, reconociendo al mismo tiempo que no constituyen límites de seguridad.

Diseñar las instrucciones del sistema

Escriba instrucciones claras que definan el rol, las tareas permitidas, las acciones prohibidas, la escalada de problemas, el uso de la fuente, la incertidumbre, las citas y el comportamiento de la herramienta. Almacene y gestione las versiones de los prompts como si fueran código. Una prompt del sistema puede guiar el comportamiento, pero los usuarios o el contenido recuperado aún pueden manipular el modelo.

- Mantenga las instrucciones concisas y verificables.
- Separe el contenido no confiable de las instrucciones.
- Indicar cuándo rechazar o solicitar aprobación
- Exigir la divulgación de la incertidumbre y la fuente cuando corresponda.
- Nunca coloques secretos en las prompts del sistema.

Controlar la memoria y el contexto

El historial de conversaciones, la memoria a largo plazo, los fragmentos recuperados, los archivos subidos y los resultados de las herramientas se convierten en contexto. Defina qué se puede almacenar, durante cuánto tiempo, quién puede recuperarlo y cómo se elimina. Evite que la memoria de un usuario influya en la sesión de otro.

- Clasificar el contenido de la memoria y establecer la retención.
- Evitar la recuperación entre usuarios y entre tenants
- Validar y etiquetar los resultados de la herramienta.
- Limitar el contexto a lo necesario
- Proporcionar un método para corregir o eliminar la información almacenada.

Utilice la seguridad del contenido como una capa

Los servicios de seguridad de contenido pueden detectar categorías de texto o imágenes dañinas y admiten filtros configurables. No garantizan la veracidad de los hechos, no previenen la fuga de datos, no imponen autorizaciones ni impiden todos los jailbreaks. Ajuste los umbrales según el caso de uso real y analice tanto los falsos negativos como los falsos positivos.

- Pruebe los filtros de entrada y salida por separado.
- Cree mensajes de respaldo seguros

- Registrar las decisiones de filtrado sin retener contenido sensible innecesariamente.
- Establecer procesos de revisión y apelación
- Vuelva a realizar la prueba después de cambios en la política, el modelo, el idioma o la audiencia.

EL SECRETO EN EL SISTEMA PROMPT

Un desarrollador coloca una credencial de base de datos en una solicitud del sistema e indica al modelo que nunca la revele. Un atacante utiliza técnicas de extracción repetidas y obtiene la credencial. Las instrucciones no pueden reemplazar a un gestor de secretos.

Práctica: Crear y probar una instrucción del sistema

- Write a system instruction for a policy assistant.
- Defina las tareas permitidas, las condiciones de rechazo, las citas, la incertidumbre y la escalada.
- Cree pruebas normales, ambiguas, hostiles y de inyección indirecta.
- Registrar los criterios de aprobación y el comportamiento inesperado.
- Mueva todas las decisiones secretas y de autorización fuera del mensaje.

Verificación de controles del capítulo

- ☐ Los prompts están versionados y revisados por pares.
- ☐ En los prompts no se guardan secretos ni decisiones de autorización final.
- ☐ La memoria tiene reglas de aislamiento, retención, corrección y eliminación.
- ☐ Los filtros de contenido se prueban y se tratan como una sola capa.

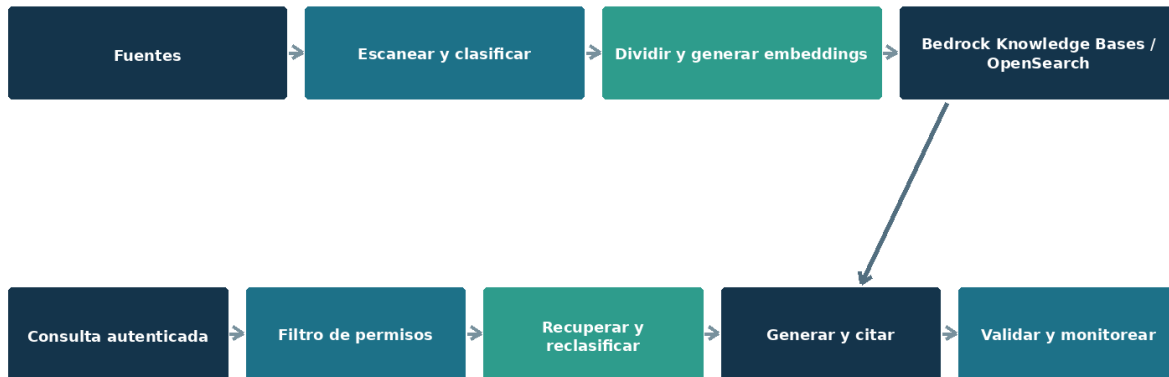
PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 12 — Generación aumentada por recuperación (RAG) segura

Cree una solución RAG que mejore las respuestas sin crear una nueva vía para sortear los controles de autorización y retención de datos.

RAG seguro: la autorización debe sobrevivir a la recuperación



El linaje y la eliminación abarcan archivos, fragmentos, embeddings, índices, prompts y registros.

Figura 5. El protocolo RAG seguro preserva la autorización, el linaje y la monitoreo a lo largo de todo el proceso.

Comprenda el flujo de trabajo RAG

RAG recupera el material relevante y lo agrega al contexto del modelo. No entrena al modelo de forma permanente ni garantiza una respuesta correcta. El proceso incluye ingesta, escaneo, análisis sintáctico, segmentación, metadatos, embeddings, indexación, consultas, filtrado, reordenamiento, generación, citación y eliminación. Cada etapa requiere un responsable y controles.

- Mantener el linaje desde el documento fuente hasta cada fragmento e embedding.
- Propietario de la fuente del registro, clasificación, permisos, región, retención y vencimiento.
- Escanee y valide los archivos antes de analizarlos.
- Mantener rastreables los cambios de origen e índice.
- Eliminación del diseño para que se elimine el contenido derivado.

Preservar la autorización durante la recuperación

El acceso a la aplicación no autoriza todos los documentos indexados. Aplique el acceso a nivel de documento o fragmento utilizando los permisos de usuario, grupos, tenant, propósito y origen autenticados.

Aplique el filtrado antes de que el contenido llegue al modelo. Nunca le pida al modelo que decida si un fragmento recuperado está permitido.

- Utilizar el recorte de seguridad y denegar por defecto.
- Pruebe de aislamiento entre usuarios y entre tenants
- Evitar la omisión del filtro de metadatos
- Utilice identidades gestionadas entre los componentes de recuperación.
- Registrar la identidad de la consulta, los filtros, los identificadores de origen y el resultado de la autorización.

Defienda la base de conocimientos

Trate cada documento como una entrada no confiable. Un documento puede contener instrucciones ocultas o visibles dirigidas al modelo. Separe los datos recuperados de las instrucciones del sistema, identifique las fuentes autorizadas, restrinja la ingesta, detecte cambios inesperados y pruebe contenido contaminado.

- Aprobar conectores y fuentes de ingestión
- Utilice sumas de verificación, procedencia y revisión de cambios para el contenido crítico.
- Detectar la inyección de prompts indirecta y las instrucciones sospechosas
- Limitar la cantidad y el contexto recuperados.
- Exigir citas que puedan abrirse y verificarse.

Evaluar la recuperación y las respuestas.

Mida la calidad de recuperación por separado de la calidad de generación. Una respuesta fluida puede basarse en una fuente errónea. Utilice preguntas representativas y evalúe la precisión, la exhaustividad, la relevancia del contexto, la fundamentación, la exhaustividad, la corrección de las citas, el rechazo, la latencia, el costo y el comportamiento de seguridad.

- Incluir en el corpus las preguntas sin respuesta.
- Pruebe documentos conflictivos, obsoletos, duplicados y maliciosos
- Establecer puntuaciones mínimas y reglas de revisión manual.
- Repita las evaluaciones después de cambios en el corpus, la segmentación, la embedding, el modelo, la indicación o la clasificación.

DOCUMENTO ELIMINADO, INCORPORADO SOBREVIVIENDO

Un documento legal se elimina del almacenamiento según una solicitud de retención, pero fragmentos permanecen en el índice de búsqueda. El asistente continúa mostrando partes porque la eliminación se implementó solo para el archivo original.

Práctica: Modelar amenazas y probar un asistente RAG

- Cree un pequeño corpus con documentos públicos, internos y restringidos.
- Defina los metadatos y los filtros de permisos.
- Agregue un documento inofensivo que contenga una cadena de prueba de inyección indirecta.
- Pruebe de recuperación autorizada, recuperación denegada, respuestas desconocidas, citas y eliminación.
- Documente cada elemento necesario para demostrar el control de acceso y la eliminación de documentos.

Verificación de controles del capítulo

- ☐ Los permisos de origen se conservan tras la ingesta y la recuperación.
- ☐ Los documentos se tratan como datos de entrada no fiables.
- ☐ El linaje y la eliminación cubren fragmentos e embeddings.
- ☐ La recuperación y la generación se evalúan por separado.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 13: Agentes, herramientas, MCP y comunicación entre agentes.

Limitar los sistemas autónomos y semiautónomos para que las instrucciones en lenguaje natural no puedan convertirse silenciosamente en una autoridad ilimitada.

Comprender el ciclo del agente

Un agente observa, razona, elige una herramienta, actúa, recibe un resultado y continúa. Cada ciclo puede amplificar un error o un ataque. Defina un objetivo delimitado, un número máximo de pasos, herramientas aprobadas, límites de tiempo y gasto, condiciones de parada y acciones que requieran aprobación humana.

- Utilice agentes especializados en áreas específicas en lugar de un agente todopoderoso.
- Establezca límites de iteración, tiempo, token y transacción.
- Validar los argumentos y resultados de la herramienta.
- Evitar la delegación recursiva sin límites
- Registre un rastro que conecte la instrucción, la decisión, la llamada a la herramienta, la identidad y el resultado.

Herramientas seguras y MCP

MCP estandariza la forma en que los modelos descubren y utilizan herramientas y contexto. Cada servidor, descripción de herramienta, esquema, recurso devuelto y flujo de autenticación se considera una decisión relacionada con la cadena de suministro y los límites de confianza. Una descripción atractiva de una herramienta no garantiza su seguridad.

- Aprobar e inventariar los servidores MCP
- Autenticar clientes y servidores
- Versiones de PIN y verificación de fuentes de distribución
- Revise las descripciones de las herramientas para detectar instrucciones ocultas o engañosas.
- Herramientas y destinos de listas de permitidos
- Ejecución de código en entorno aislado y acceso a archivos
- Requerir confirmación para acciones consecuentes

Delegación de control y confianza entre agentes

Un agente que recibe una solicitud de otro agente no debe asumir que el remitente está autorizado para la acción solicitada. Autentique a ambas partes, conserve el usuario y el propósito de origen, restrinja los ámbitos delegados y registre la cadena de autoridad.

- Utilice relaciones de confianza explícitas

- Evite pasar fichas anchas reutilizables.
- Establecer la profundidad y la fecha de vencimiento de la delegación.
- Separar el intercambio de datos de las instrucciones ejecutables
- Detectar el trabajo circular, la desviación de tareas y la acumulación de privilegios.

LA HERRAMIENTA ÚTIL PERO MALICIOSA

Un desarrollador instala un servidor MCP no revisado que ofrece una conversión de documentos sencilla. Los metadatos de la herramienta indican al modelo que envíe el contenido del documento a un endpoint externo. El agente sigue la descripción porque el servidor se consideró de confianza.

Práctica: Revisar el diseño de un agente

- Defina un objetivo empresarial y las herramientas mínimas necesarias.
- Asigne una identidad y un conjunto de permisos distintos a cada agente y herramienta.
- Enumere las acciones que requieren confirmación.
- Establezca límites de pasos, tiempo, costo, destino y transacción.
- Redacte los procedimientos de cierre y de preservación de pruebas.

Verificación de controles del capítulo

- ☐ Los agentes tienen objetivos, tiempo, pasos, coste y permisos limitados.
- ☐ Los servidores y herramientas de MCP están inventariados y aprobados.
- ☐ La delegación preserva la identidad, el propósito, el alcance y la auditabilidad.
- ☐ Las acciones con consecuencias requieren controles deterministas o aprobación humana.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 14 — Amazon Q e IA para la productividad empresarial

Garantizar el uso organizacional de Amazon Q y otros asistentes de productividad cuando los permisos existentes y el exceso de compartición de información se conviertan en riesgos para la IA.

El acceso existente se convierte en alcance de la IA

Un asistente de productividad puede descubrir y resumir rápidamente la información a la que el usuario ya tiene acceso. Puede revelar el uso excesivo de información durante mucho tiempo, información que era difícil de detectar manualmente. Antes de la implementación generalizada, revise los permisos de SharePoint, Teams, OneDrive, el buzón de correo y los grupos, y establezca la propiedad de los repositorios confidenciales.

- Descubra información compartida en exceso y sin etiquetar.
- Eliminar enlaces generales y membresías de grupos obsoletas.
- Aplicar etiquetas de sensibilidad y DLP
- Priorizar los datos ejecutivos, legales, de recursos humanos, financieros, de seguridad y de clientes.
- Pruebe con roles de usuario representativos

Gobernar agentes y extensiones

Las aplicaciones, complementos, conectores, acciones y fuentes de datos indexadas de Amazon Q Business amplían las capacidades y también los riesgos. Establezca un proceso de admisión, entornos aprobados, política de conectores, requisitos para el propietario y el patrocinador, clasificación de datos, pruebas, aprobación de publicación, monitoreo y retiro.

- Roles separados de creador y editor de producción
- Restringir los conectores y las rutas de pérdida de datos.
- Políticas de uso del entorno y de los tenants
- Agentes publicados del inventario
- Revisar propietarios, permisos, uso e inactividad

Gestionar la adopción de forma segura

Los usuarios necesitan ejemplos claros de información permitida y prohibida, cómo verificar las respuestas, cuándo se requiere revisión humana y cómo reportar un problema. Bloquear todas las herramientas sin una alternativa aprobada fomenta la IA encubierta.

- Proporcionar formación específica para cada puesto
- Publicar un directorio de herramientas aprobadas

- Explique que el contenido generado puede ser incorrecto.
- Exigir verificación de origen para trabajos importantes
- Medir las conductas de riesgo y mejorar los controles sin tratar la educación como vigilancia.

COPILOT ENCUENTRA LO QUE LA BÚSQUEDA NO PUDO ENCONTRAR

Un gerente solicita información sobre la planificación salarial. Copilot localiza una hoja de cálculo compartida a través de un antiguo enlace de toda la organización. Copilot no eludió los permisos; simplemente facilitó la explotación de una vulnerabilidad de control de acceso ya existente.

Práctica: Preparar el despliegue de una IA para aumentar la productividad.

- Identifique cinco depósitos de alto riesgo.
- Defina los permisos, el etiquetado, la prevención de pérdida de datos (DLP) y las comprobaciones de propiedad.
- Cree reglas de publicación de agentes y aprobación de conectores.
- Escriba diez ejemplos de uso seguro y cinco ejemplos de uso prohibido.
- Defina las métricas de adopción, riesgo e incidentes.

Verificación de controles del capítulo

- ☐ El problema de compartir información en exceso se aborda antes de su implementación a gran escala.
- ☐ Los agentes, conectores y extensiones tienen gobernanza del ciclo de vida.
- ☐ Los usuarios pueden distinguir entre servicios aprobados y personales.
- ☐ Los resultados importantes requieren verificación y responsabilidad humana.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

PARTE III — PROTECCIÓN DE LOS SISTEMAS DE IA

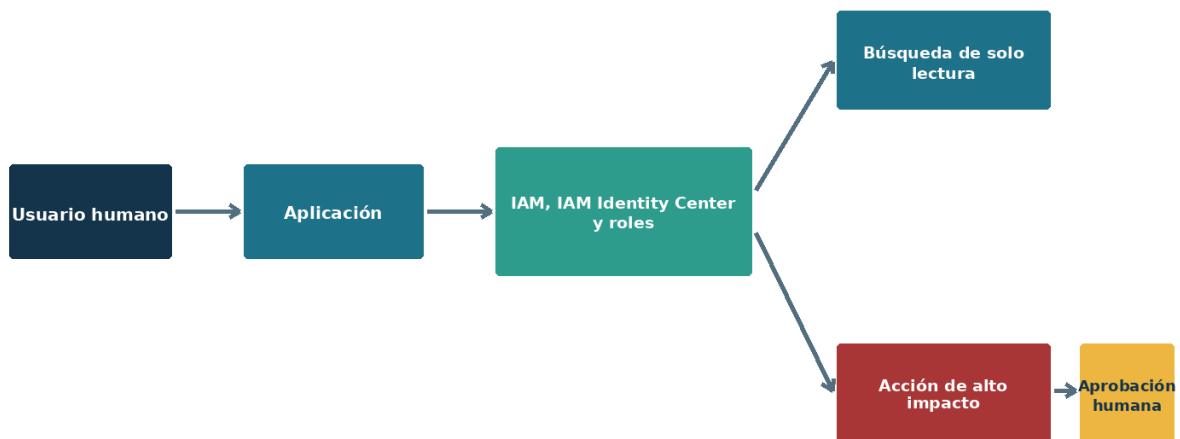
Aplicar medidas de seguridad para la identidad, los datos, las aplicaciones, los modelos y la infraestructura.

COMPRENDER • APLICAR • PROBAR • DEMOSTRAR

Capítulo 15 — Seguridad de la identidad e identidades no humanas

Otorgue a cada usuario, carga de trabajo, aplicación y agente una identidad controlada con autoridad limitada y un ciclo de vida completo.

La identidad y la aprobación limitan la autoridad del agente



Registre usuario, agente, alcance delegado, herramienta, decisión de autorización y resultado.

Figura 6. La identidad del agente y la aprobación humana limitan la autoridad delegada.

Elegir la identidad adecuada

AWS IAM Identity Center gestiona el acceso de la fuerza laboral, mientras que los roles de IAM representan aplicaciones, servicios, automatización y agentes. Los roles de carga de trabajo y AWS STS evitan almacenar muchas credenciales de larga duración. Elija un tipo de identidad que admita autenticación de corta duración, propiedad clara, autorización restringida y registros útiles.

- Evite compartir cuentas de usuario o de servicio.
- Prefiera la identidad administrada o la federación de identidades de carga de trabajo.
- Utilice únicamente entidades de servicio con propiedad y propósito documentados.
- Utilice identidades de agente dedicadas para los agentes gobernados.
- No permita que los humanos realicen trabajos rutinarios a través de identidades no humanas.

Gobernar el ciclo de vida de las NHI

Las identidades no humanas suelen ser más numerosas que las personas y se olvidan con facilidad. Cada identidad requiere un registro de inventario, un propietario o patrocinador, un propósito, un entorno,

credenciales, permisos, dependencias, fecha de creación, fecha de revisión y un mecanismo para su eliminación.

- Descubre identidades desconocidas e inactivas.
- Revisar permisos y uso reciente
- Rotar o eliminar secretos de larga data
- Identidades separadas para desarrollo, pruebas y producción.
- Deshabilitar antes de eliminar cuando las dependencias son inciertas
- Eliminar identidades, consentimientos, roles, secretos y relaciones de confianza durante el proceso de desvinculación.

Aplicar las recomendaciones de OWASP para NHI

La lista OWASP Non-Human Identities Top 10 destaca la desvinculación inadecuada de usuarios, la filtración de secretos, las identidades de terceros vulnerables, la autenticación insegura, los privilegios excesivos, la configuración insegura en la nube, los secretos de larga duración, el aislamiento deficiente del entorno, la reutilización de identidades y el uso humano de identidades no humanas. Considere esta lista como una lista de verificación para el diseño y la auditoría.

- Analizar repositorios, canalizaciones, imágenes y configuraciones en busca de secretos.
- Utilice certificados o federación en lugar de claves estáticas siempre que sea posible.
- Asigne los ámbitos de recursos y API más restringidos.
- Evaluar agentes de terceros y automatización
- Alerta sobre inicios de sesión inusuales, ubicaciones, uso de tokens y cambios de permisos.

Control del acceso delegado y autónomo

Un agente de asistencia puede actuar en nombre de un usuario que haya iniciado sesión, mientras que un agente autónomo puede usar los permisos de la aplicación. Registre tanto al actor como al sujeto representado. La delegación no debe ampliar silenciosamente el acceso del usuario, y los permisos autónomos deben ser especialmente limitados.

- Distinguir entre permisos delegados y permisos de aplicación
- Requerir consentimiento y aprobación apropiados para el impacto
- Conservar la identidad del usuario, el agente, el propósito y la herramienta en los registros.
- Utilice la aprobación humana para acciones delicadas.
- Cree una ruta de revocación de emergencia probada

EL PROPIETARIO SE VA, PERO EL AGENTE SE QUEDA.

Un empleado crea un agente con amplios permisos de aplicación y luego abandona la empresa. La

cuenta de usuario se desactiva, pero la identidad y la clave secreta del agente siguen funcionando porque la propiedad y la desvinculación nunca se vincularon.

Práctica: Crear un registro del NHI

- Inventaría cinco ejemplos de identidades gestionadas, entidades de servicio, canalizaciones, claves API y agentes.
- Propietario del registro, propósito, permisos, credenciales, entorno y último uso.
- Identificar la reutilización, los privilegios excesivos, los secretos de larga duración y la falta de procesos de baja de empleados.
- Redacte los pasos para la subsanación y la revocación de emergencia.
- Defina las evidencias para una revisión de acceso trimestral.

Verificación de controles del capítulo

- ☐ Cada NHI es único, tiene propietario, está destinado a un propósito específico y está inventariado.
- ☐ Se prefiere la autenticación de corta duración o federada.
- ☐ Se imponen el aislamiento ambiental y el principio de mínimo privilegio.
- ☐ El proceso de desvinculación elimina la identidad, las credenciales, los permisos, el consentimiento y las dependencias.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 16 — Macie, DataZone, gobernanza de datos, privacidad y Shadow AI

Proteja la información tanto en el uso aprobado como en el no aprobado de la IA, preservando al mismo tiempo la clasificación, el propósito, la retención y las pruebas.

Conocer el patrimonio de datos

Amazon Macie descubre datos confidenciales en Amazon S3, mientras que AWS Lake Formation, AWS Glue Data Catalog y Amazon DataZone respaldan el descubrimiento, los permisos, el linaje y el intercambio gobernados. Comience con un inventario de fuentes confidenciales, propietarios, permisos, ubicaciones y usos de IA. La clasificación sin propiedad ni acción se convierte en mero adorno.

- Utilice las funciones de Mapa de datos y catálogo para comprender las fuentes y el linaje.
- Aplique etiquetas de sensibilidad que coincidan con el significado comercial.
- Identificar datos regulados, confidenciales y de alto impacto.
- Registrar los fines de IA aprobados y los usos prohibidos.
- Revise el exceso de intercambio de información antes de habilitar el descubrimiento de IA a gran escala.

Aplicar controles de seguridad de datos

La protección de la información, la prevención de pérdida de datos, la auditoría, el descubrimiento electrónico, la retención, el riesgo interno, el cumplimiento de las comunicaciones y la gestión de la seguridad de los datos (DSPM) para IA abordan diferentes aspectos del problema. Configúrelos según el riesgo, las licencias, la jurisdicción y las expectativas de la plantilla.

- Detectar información sensible en los prompts y respuestas.
- Restringir la copia o la carga cuando el riesgo lo requiera.
- Supervise el acceso y el intercambio inusuales.
- Conservar los registros y las retenciones legales
- Proteja los datos de la investigación y limite el acceso de los revisores.
- Pruebe las políticas en modo auditoría antes de su aplicación cuando corresponda.

Gestionar la IA en la sombra

Shadow AI incluye servicios de chat no autorizados, cuentas personales, extensiones de navegador, modelos, agentes, conectores y claves API. Combina detección, políticas, controles técnicos, capacitación y una alternativa aprobada y sencilla. Una prohibición sin herramientas útiles fomenta el trabajo oculto.

- Publicar un directorio de servicios aprobados
- Explique los datos permitidos por servicio y tipo de cuenta.
- Detectar actividad de navegación y red riesgosa cuando sea legal.
- Ofrecer un mecanismo para solicitar nuevas herramientas.
- Medir la adopción y el comportamiento de riesgo
- Responder de forma proporcional y mejorar el sistema tras los hallazgos.

Privacidad desde el diseño

Defina la finalidad, la base legal, la notificación, el consentimiento cuando sea necesario, la minimización, el acceso, la corrección, la retención, la eliminación, la transferencia transfronteriza y la gestión de derechos antes de procesar información personal. Los prompts, los resultados, los elementos incrustados, los registros y las revisiones humanas pueden contener datos personales.

- Complete una evaluación de impacto en la privacidad o la protección de datos para usos de mayor riesgo.
- Evite recopilar datos simplemente porque puedan ser útiles más adelante.
- Redactar o tokenizar donde sea posible
- Limitar los datos de producción en el desarrollo y las evaluaciones.
- Pruebe de eliminación en origen, índice, memoria, registros y copias de seguridad.

EL INQUILINO APROBADO Y LA PESTAÑA DEL NAVEGADOR PERSONAL

Una organización adquiere una licencia para un servicio de IA empresarial, pero los empleados siguen utilizando cuentas personales porque el flujo de trabajo aprobado es más lento. Por lo tanto, las notificaciones confidenciales salen del entorno controlado.

Práctica: Crear un plan de protección de datos de IA

- Seleccione un caso de uso de IA y enumere todas las fuentes de datos y los tipos de datos derivados.
- Asigne clasificación, propietario, propósito, acceso, región, retención y método de eliminación.
- Defina los resultados de Macie, los permisos de Lake Formation, la gobernanza de DataZone, la auditoría y la postura de seguridad de los datos.
- Redactar una guía para empleados con alternativas seguras.
- Pruebe un escenario de acceso, un escenario de DLP y un escenario de eliminación.

Verificación de controles del capítulo

- ☐ Se registra la propiedad, la clasificación, el linaje y el propósito permitido de los datos.

- ☐ Se incluyen prompts, salidas, embeddings, memoria y registros.
- ☐ Shadow AI cuenta con descubrimiento, políticas, entrenamiento y alternativas aprobadas.
- ☐ Los derechos de privacidad y la eliminación funcionan en todos los datos derivados.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 17: Infraestructura, red, secretos y protección de API.

Reforzar las capas habituales de la nube y las aplicaciones que gestionan el tráfico y la autoridad de la IA.

Proteja las rutas de la red

Utilice puntos de acceso privados para servicios sensibles cuando sea compatible, controle la salida, segmente los entornos y dirija el acceso externo a través de pasarelas gestionadas. Documente el DNS, los certificados, los cortafuegos, los proxies y las dependencias. Las redes privadas reducen la exposición, pero no sustituyen la identidad ni la autorización de aplicaciones.

- Deshabilitar el acceso a la red pública cuando no sea necesario.
- Restringir los destinos de salida para agentes y herramientas
- Utilice la protección de aplicaciones web y API.
- Registro de flujos aceptados y rechazados
- Pruebas desde redes autorizadas y no autorizadas.

Gestionar secretos y claves

Utilice AWS Secrets Manager y AWS Key Management Service (AWS KMS) para secretos, claves y certificados, pero prefiera diseños que eviten el uso de secretos mediante roles de IAM, federación de cargas de trabajo y credenciales temporales de AWS STS. Separe las funciones de administración y uso. Proteja las operaciones de recuperación y eliminación, ya que borrar una clave puede destruir el acceso a los datos protegidos.

- Nunca guardes claves en mensajes, código, cuadernos, imágenes o tickets.
- Rotación de credenciales y rotación de pruebas
- Utilice permisos de bóveda y objetos restringidos.
- Habilitar el registro y la protección de recuperación adecuada.
- Inventariar a los consumidores antes de cambiar o retirar sus credenciales.

API seguras y endpoints de herramientas

Utilice Amazon API Gateway o controles equivalentes para la autenticación, autorización, esquemas, cuotas, límites de velocidad, tamaño de solicitud, métodos permitidos, control de versiones y observabilidad. Valide los argumentos de la herramienta generados por el modelo exactamente como si fueran datos de entrada de usuario no confiables.

- Utilice ámbitos de OAuth y validación de audiencia.
- Rechazar campos desconocidos y destinos no seguros.

- Aplicar idempotencia a acciones que puedan repetirse
- Establecer cuotas por usuario y por agente.
- Devolver errores seguros
- No coloque información confidencial en las URL ni en los registros.

Utilice Security Hub y la gestión de la postura

Las recomendaciones, alertas, información sobre vulnerabilidades y protecciones de carga de trabajo de AWS Security Hub CSPM, GuardDuty y Amazon Inspector proporcionan una visibilidad útil. Permiten priorizar por exposición e impacto en el negocio, verificar la aplicabilidad, asignar responsables y realizar un seguimiento de las medidas correctivas. Un panel de control no implica que el riesgo se haya aceptado o solucionado.

- Habilitar planes y configuraciones de diagnóstico relevantes
- Revisar las recomendaciones relacionadas con la IA
- Integrar las alertas con los procesos de incidentes.
- Validar la remediación
- Excepciones aceptadas y vencimiento del documento

EL PUNTO FINAL PRIVADO CON UN SECRETO PÚBLICO

Un endpoint modelo utiliza una red privada, pero su clave se encuentra en un repositorio público. Los controles de red dificultan el ataque, pero la credencial aún puede utilizarse desde una ruta permitida o a través de otro componente comprometido.

Práctica: Revisar una ruta de servicio segura

- Dibujar conexiones entre el usuario, la API, el modelo, la búsqueda y el almacenamiento.
- Marque los endpoints públicos y privados, así como los destinos de salida.
- Elija la identidad y el manejo de secretos para cada conexión.
- Defina la validación y los límites de la API.
- Enumerar los registros y las alertas necesarios para investigar una solicitud de principio a fin.

Verificación de controles del capítulo

- ☐ El acceso público y saliente está explícitamente justificado.
- ☐ La identidad gestionada reemplaza los secretos almacenados cuando resulta práctico.
- ☐ Las entradas de API generadas por el modelo se validan como no confiables.
- ☐ Los hallazgos sobre la postura se convierten en trabajo de remediación propio y verificado.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 18 — Riesgos de OWASP para LLM, agentes, NHI, API y aplicaciones web

Utilice las familias de OWASP de forma conjunta para que los riesgos específicos de la IA no oculten las debilidades de las aplicaciones convencionales.

OWASP Top 10 para aplicaciones LLM

La lista LLM 2025 abarca la inyección de prompts, la divulgación de información sensible, el riesgo en la cadena de suministro, la contaminación de datos y modelos, el manejo inadecuado de resultados, la excesiva intervención, la fuga de información del sistema, las debilidades de los vectores y la embedding, la desinformación y el consumo ilimitado. Asigne cada elemento a la arquitectura, las pruebas, el monitoreo y la respuesta.

- La inyección de prompts requiere separación de entradas, privilegios mínimos, aprobación y monitoreo.
- La divulgación sensible requiere autorización, minimización, DLP y gestión de salida.
- Los riesgos de contaminación y de la cadena de suministro requieren procedencia, aprobación, integridad y detección de cambios.
- El manejo inadecuado de la salida requiere codificación y validación.
- Un exceso de autonomía requiere herramientas limitadas y límites deterministas.
- El consumo ilimitado requiere cuotas, límites de velocidad, presupuestos y detección de anomalías.

OWASP Top 10 para aplicaciones agentic

Los sistemas basados en agentes introducen manipulación de objetivos, mal uso de herramientas, abuso de identidad y privilegios, memoria insegura, comunicación insegura, fallos en cascada y problemas de confianza entre humanos y agentes. Consulte la guía actual de OWASP sobre sistemas basados en agentes al diseñar o modificar agentes, ya que este ámbito evoluciona rápidamente.

- Vincular a los agentes a los objetivos aprobados
- Autenticar la comunicación entre agentes y entre agentes y herramientas.
- Controlar la escritura y recuperación de la memoria
- Limitar la profundidad y los privilegios de delegación

- Requieren control humano sobre los resultados consecuentes.
- Detectar bucles, desviaciones y fallos coordinados

Guías de OWASP para NHI, API y aplicaciones web

Las aplicaciones de IA siguen siendo aplicaciones web y API. Utilice NHI Top 10 para identidades de máquinas, API Security Top 10 para interfaces expuestas, Web Top 10 para riesgos de aplicaciones, ASVS para requisitos de verificación y SAMM para madurez del programa.

- La autorización defectuosa sigue siendo una de las principales preocupaciones.
- La inyección incluye SQL, comandos, plantillas y solicitudes.
- Una configuración de seguridad incorrecta afecta a los servicios en la nube, de aplicaciones y de modelos.
- Los fallos de dependencia e integridad se extienden por toda la cadena de suministro de IA.
- El registro y las alertas deben conectar los eventos de la aplicación y de la IA.

Convertir listas en trabajo de ingeniería

Una lista de los 10 principales riesgos es una herramienta de concienciación, no un modelo de amenazas completo. Cree casos de prueba, asigne responsables de control, recopile evidencias y defina criterios de aceptación para los riesgos aplicables. Registre por qué un riesgo no es aplicable en lugar de dejarlo en blanco.

- Mapeo de riesgos a componentes y flujo de datos
- Identificar controles preventivos y de detección
- Crear pruebas positivas y negativas
- Defina la gravedad y la respuesta.
- Repetir la prueba después del cambio de material.

LA SALIDA SE CONVIERTE EN CÓDIGO

Un modelo resume un documento y devuelve un texto con código de script. La aplicación inserta el resultado en una página web sin codificarlo. Los controles de solicitud funcionan, pero un manejo inadecuado del resultado crea un riesgo de secuencias de comandos entre sitios (XSS).

Práctica: Construya una matriz de control de OWASP

- Seleccione un caso de uso del agente RAG.
- Evaluar los 10 elementos principales del LLM y los riesgos relevantes relacionados con agentes, NHI, API y web.
- Asigne a cada riesgo aplicable el control, el propietario, la prueba, la evidencia y la respuesta.

- Realice al menos una prueba segura con resultado negativo para cada uno de los cinco riesgos.
- Registrar los riesgos residuales y las decisiones tomadas.

Verificación de controles del capítulo

- ☐ Los riesgos relacionados con LLM, agentes, NHI, API y web se evalúan conjuntamente.
- ☐ Las listas de OWASP complementan, en lugar de reemplazar, los modelos de amenazas.
- ☐ Cada riesgo aplicable tiene un control, una prueba, un responsable y una evidencia.
- ☐ La salida se valida antes de que otro sistema la interprete.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 19 — Cadena de suministro de IA, desarrollo seguro y LLMOps

Proteja los modelos, los datos, el código, los prompts, los paquetes, los contenedores, las canalizaciones y los artefactos de implementación desde su creación hasta su retirada.

Inventariar la cadena de suministro de IA

Una lista de materiales para IA debe identificar modelos, proveedores, conjuntos de datos, embeddings, paquetes, imágenes de contenedor, prompts, herramientas, servidores MCP, API, conjuntos de evaluación, licencias y servicios de implementación. Se debe registrar el origen, la versión, la integridad, el propietario, la aprobación, el entorno y las limitaciones conocidas.

- Utilice registros y repositorios aprobados.
- Verifique las sumas de comprobación, las firmas y la procedencia cuando estén disponibles.
- Analizar el código, las dependencias, las imágenes y las plantillas de infraestructura.
- Revisar las licencias del modelo y del conjunto de datos
- Supervise los avisos de los proveedores y las notificaciones de fin de vida útil.

Aplicar un ciclo de vida de desarrollo seguro

Utilice los principios SSDF del NIST y las prácticas específicas de IA en la planificación, el desarrollo, la compilación, el lanzamiento y la respuesta. Proteja el control de versiones, exija la revisión por pares, separe las funciones, escanee los secretos y mantenga el despliegue en producción controlado y repetible.

- Modelo de amenazas antes de la implementación
- Utilice la protección de sucursales y revise los cambios.
- Genera infraestructura repetible con Bicep o Terraform.
- Firma y seguimiento de los comunicados
- Requieren controles de seguridad, protección, calidad, privacidad y costos.
- Mantener un proceso de respuesta ante vulnerabilidades y problemas.

Opere LLMOps con evidencia

Modelos de versiones, prompts, configuración de recuperación, conjuntos de datos, código, filtros, políticas, herramientas y definiciones de evaluación. Un registro de versiones debería permitir reproducir lo que se probó y comprender los cambios.

- Utilice entornos separados y promoción aprobada.
- Mantener las líneas de base de evaluación
- Detectar la deriva y la regresión

- Revertir rápidamente
- Retire los endpoints, las identidades, los índices, los datos y las dependencias en conjunto.

Controlar modelos de código abierto y de terceros

Los modelos de código abierto ofrecen flexibilidad, pero aumentan la responsabilidad del cliente en cuanto al origen, la integridad, la licencia, el alojamiento, las actualizaciones, la alineación con la seguridad y la monitoreo. Los modelos gestionados por terceros transfieren algunas operaciones, pero aún requieren la debida diligencia y controles de la aplicación.

- Obtenga modelos de fuentes confiables.
- Revise las tarjetas modelo y las limitaciones.
- Pruebe de puertas traseras, comportamiento inseguro y capacidad inesperada
- Aislar los entornos de evaluación
- Documento de uso aceptado y datos prohibidos

UN PAQUETE CONVENIENTE CAMBIA EL PLAN DE PRODUCCIÓN

Un desarrollador instala un popular paquete de herramientas de IA. Una actualización comprometida lee las variables de entorno durante la compilación y envía las credenciales de implementación fuera de la organización.

Práctica: Cree una lista de materiales para IA.

- Inventaría los modelos, datos, código, bibliotecas, imágenes, prompts, herramientas, API y servicios en la nube de una aplicación de ejemplo.
- Proveedor del registro, versión, licencia, integridad, propietario y entorno.
- Identifique tres dependencias con un alto impacto en la sustitución o el compromiso.
- Defina el seguimiento y la respuesta para cada uno.
- Cree una lista de verificación de evidencia para la liberación.

Verificación de controles del capítulo

- ☐ El inventario incluye componentes de software convencionales y de IA.
- ☐ Los procesos de compilación y lanzamiento utilizan revisión, integridad y separación de funciones.
- ☐ Cada versión de producción es reproducible y reversible.
- ☐ La jubilación elimina los datos, las identidades y los servicios conectados.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados

de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 20 — Evaluación, Red Teaming y pruebas de seguridad

Medir si un sistema de IA es útil, seguro, protegido, privado, fiable y asequible en condiciones realistas y adversas.

Elaborar una estrategia de evaluación

Comience con el caso de uso y los escenarios de riesgo. Cree datos de prueba representativos, el comportamiento esperado, los métodos de puntuación, los umbrales y las reglas de revisión. Separe la calidad del modelo de la recuperación, la seguridad, la privacidad, la latencia, la fiabilidad y el coste para que un buen promedio no oculte un fallo crítico.

- Incluir casos comunes, raros, ambiguos, multilingües y contenciosos.
- Evaluar los grupos protegidos y las necesidades de accesibilidad.
- Incluir casos con información faltante o contradictoria
- Defina los fallos inaceptables independientemente de la puntuación media.
- Mantenga los datos de prueba controlados y con versiones.

Realizar ejercicios de Red Team de forma segura

Las pruebas de penetración con IA simulan el uso indebido y el comportamiento malicioso. Requieren autorización, definición del alcance, objetivos seguros, condiciones de parada, gestión de datos, comunicaciones y responsabilidad en la corrección de errores. Las herramientas automatizadas aumentan la cobertura, pero no sustituyen las pruebas humanas creativas ni la revisión de la arquitectura.

- Utilice objetivos aislados o que no sean de producción siempre que sea posible.
- Evite información realmente sensible
- Pruebe de inyección directa e indirecta
- Extracción de pruebas, envenenamiento, abuso de herramientas, exceso de control, evasión y agotamiento de costos.
- Conservar prompts, respuestas, rastros, configuración y marcas de tiempo.

Utilice las herramientas de forma responsable.

PyRIT y las capacidades de evaluación de modelos de Amazon Bedrock, garak, promptfoo, Giskard e Inspect AI permiten realizar pruebas estructuradas. Configúrelas únicamente en sistemas de su propiedad o para los

que tenga autorización de prueba. Revise la documentación de la herramienta y el tráfico generado antes de su ejecución.

- Herramienta de grabación y versión
- Utilice cuentas de prueba y límites aprobados.
- Desinfecta los resultados antes de compartirlos.
- Confirme los resultados manualmente.
- Convertir los resultados en pruebas de regresión

Convertir los resultados en acciones concretas

Un hallazgo útil explica el escenario, las condiciones previas, la evidencia, el impacto, los componentes afectados, la probabilidad, la brecha de control y la acción recomendada. Asigne un responsable y una fecha límite, vuelva a probar la remediación y documente el riesgo residual.

- Priorizar el daño y la posibilidad de explotación por encima de la novedad.
- Separe los hechos confirmados de los posibles impactos.
- Proteja los resultados confidenciales de las pruebas.
- Seguimiento de patrones de fallos repetidos
- Informe claramente sobre los obstáculos de lanzamiento que no se hayan resuelto.

UNA CALIFICACIÓN MEDIA APROBADA OCULTA UN FRACASO CRÍTICO

Un asistente obtiene una puntuación del 96 % en un conjunto de datos de calidad, pero revela información restringida en dos pruebas de autorización. El promedio parece excelente; el sistema no debe ser lanzado.

Práctica: Diseñar una evaluación de IA segura

- Defina cinco pruebas de calidad, cinco de seguridad, cinco de protección y cinco de privacidad.
- Establecer umbrales y fallos que bloqueen la liberación.
- Elija una herramienta o método manual aprobado.
- Realizar pruebas en un entorno controlado y preservar las pruebas.
- Escriba un hallazgo y conviértelo en una prueba de regresión.

Verificación de controles del capítulo

- ☐ La evaluación abarca calidad, seguridad, protección, privacidad, fiabilidad y coste.
- ☐ Los fallos críticos no se pueden promediar.
- ☐ Las pruebas de penetración (red teaming) están autorizadas, delimitadas, limitadas y documentadas.

- ☐ Los resultados confirmados se convierten en pruebas de regresión.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

PARTE IV — GOBERNANZA Y OPERACIONES

Utilice la IA de forma responsable, mida los riesgos y preserve las pruebas.

COMPRENDER • APLICAR • PROBAR • DEMOSTRAR

Capítulo 21 — Registro, detección, investigación y respuesta ante incidentes

Conectar el comportamiento de la IA con la identidad, los datos, las aplicaciones, la red y la evidencia en la nube para que los incidentes puedan detectarse y contenerse.

La respuesta a incidentes de IA conserva control y contexto



Revoque identidades y herramientas sin destruir los rastros necesarios para comprender alcance y causa.

Figura 7. La contención debe preservar el contexto necesario para la investigación y la recuperación.

Diseñar un registro de auditoría de extremo a extremo

Un registro útil conecta la identidad del usuario o la carga de trabajo, la sesión, el agente, la implementación del modelo, la versión de la plantilla de solicitud, las fuentes de datos, los identificadores de documentos recuperados, los filtros, las llamadas a herramientas, las decisiones de autorización, los eventos de seguridad de contenido, la respuesta y el costo. Evite registrar contenido confidencial a menos que sea necesario y esté protegido.

- Utilice identificadores de correlación entre servicios.
- Sincronizar la hora
- Proteja la integridad y el acceso a los registros.
- Definir la retención por investigación y necesidad legal
- Pruebe que los investigadores puedan reconstruir una transacción.

Detectar comportamientos significativos

Alerta sobre uso inusual de identidades, cambios de permisos, acceso secreto, volumen de consultas, recuperación denegada, señales de inyección de prompts, omisión de políticas, nuevos conectores, destinos

inesperados, bucles de agentes, fallos de herramientas, picos de costos y cambios en la configuración de producción.

- Cree líneas base por usuario, agente, modelo y aplicación.
- Sintonizar las alertas con las partes interesadas en operaciones y privacidad.
- Priorizar las señales combinadas
- Resultado de la investigación del registro
- Mejorar la detección después de incidentes y ejercicios de equipos rojos.

Prepare planes de actuación ante incidentes de IA.

Los manuales de procedimientos deben abarcar la divulgación de información confidencial, la vulneración de la información sanitaria nacional, la inyección de prompts, el RAG envenenado, el MCP o conector malicioso, la salida perjudicial, las acciones inseguras, la vulneración del proveedor, la interrupción del servicio y el aumento descontrolado de los costos. Defina la contención que no destruya la evidencia.

- Deshabilitar o restringir el acceso a agentes y herramientas
- Revocar tokens, secretos, consentimiento y sesiones
- Fuentes, índices o conectores de cuarentena
- Revertir modelo, solicitud, código o política
- Conservar rastros y contenido afectado.
- Notificar a los departamentos legal, de privacidad, de seguridad, a los proveedores y a los clientes según sea necesario.

Recuperarse y aprender

Restaurar solo después de comprender la causa y el alcance afectado. Validar los controles y ejecutar pruebas de regresión antes de reabrir. Realizar una revisión imparcial que identifique mejoras técnicas, de procesos y organizativas.

- Confirmar la integridad de los datos y los índices.
- Cambios de identidad y permisos de prueba
- Supervise atentamente después de la restauración.
- Actualizar los modelos de amenazas y los planes de acción.
- Seguimiento de las lecciones hasta su finalización.

SIN IDENTIFICADOR DE TRANSACCIÓN COMÚN

El equipo de seguridad detecta un inicio de sesión sospechoso, el equipo de operaciones observa un aumento repentino de costos y el equipo de aplicaciones detecta llamadas inusuales a herramientas. Sin un identificador de correlación compartido, no es posible vincular los eventos

rápidamente.

Práctica: Realizar un ejercicio de simulación (tabletop)

- Elija un escenario de RAG envenenado o agente comprometido.
- Identificar las primeras señales y a quienes toman las decisiones.
- Practique la contención, la preservación de pruebas, la comunicación, la recuperación y la notificación.
- Registrar los registros, permisos, contactos y procedimientos que falten.
- Asigne las mejoras y programe una nueva prueba.

Verificación de controles del capítulo

- ☐ Una transacción puede rastrearse a través de la identidad, la aplicación, el modelo, los datos y las herramientas.
- ☐ El registro de datos sensibles se minimiza y se protege.
- ☐ Existen y se ponen en práctica manuales de procedimientos específicos para la IA.
- ☐ La recuperación requiere validación y pruebas de regresión.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 22 — Fiabilidad, resiliencia, rendimiento y FinOps

Garantizar la fiabilidad y la asequibilidad de los servicios de IA, evitando al mismo tiempo que las interrupciones, los bucles y el abuso de recursos se conviertan en incidentes de seguridad.

Diseñar considerando los fallos

Los modelos, proveedores, regiones, redes, índices y herramientas dependientes pueden fallar o sufrir ralentizaciones. Defina tiempos de espera, reintentos con retroceso, disyuntores, colas, mecanismos de reserva y procedimientos manuales. Asegúrese de que una solicitud repetida no pueda duplicar un pago, una eliminación o una acción de ticket.

- Establecer objetivos de tiempo y punto de recuperación
- Utilice la idempotencia para acciones repetibles.
- Fallo del proveedor de pruebas y de la región
- Defina la degradación elegante
- Mantén un modo seguro que limite las acciones autónomas.

Controlar el consumo

Los tokens, las búsquedas, las llamadas a herramientas, el almacenamiento, las evaluaciones y la monitoreo generan costos. Los ataques de denegación de pago y los bucles accidentales pueden agotar los presupuestos o las cuotas de servicio. Establezca límites a nivel de usuario, agente, aplicación, proyecto y suscripción.

- Configure presupuestos y alertas
- Límites de tasa de uso, token, solicitud y concurrencia
- Limitar los pasos del agente y las llamadas a herramientas
- Almacenar en caché de forma segura cuando sea apropiado.
- Detectar gastos y usos inusuales
- Asignar la propiedad de los costos con etiquetas y contracargos.

Medir el rendimiento sin debilitar los controles

Las mejoras en la latencia no deben obviar la autorización, el filtrado, el registro ni la validación. Mida todo el recorrido del usuario e identifique las etapas costosas o lentas. Elija modelos más pequeños cuando cumplan los requisitos y distribuya las tareas según el riesgo y la complejidad.

- Medir el tiempo de recuperación, del modelo, de la herramienta y de la red por separado.
- Carga de prueba y cuotas

- Proteja las cachés contra fugas entre usuarios.
- Incluir servicios de seguridad en las pruebas de rendimiento.
- Reevaluar el costo y la calidad después de los cambios en el modelo.

Utilice la perspectiva de arquitectura bien diseñada

Analice las cargas de trabajo de IA considerando la confiabilidad, la seguridad, la optimización de costos, la excelencia operativa y la eficiencia del rendimiento. Las compensaciones deben ser explícitas. Un diseño más económico que pierda capacidad de auditoría o un diseño seguro que no permita la recuperación pueden resultar inaceptables.

- Documentar los requisitos no funcionales
- Realizar evaluaciones de arquitectura
- Asignar mejoras
- Repetir la prueba después de un cambio importante.
- Registro de intercambios aceptados y propietarios

LA TORMENTA DE REINTENTOS

La API de una herramienta se ralentiza. Cientos de agentes reintentan la operación inmediatamente, aumentando la carga y el coste hasta que la dependencia falla. El retroceso, los disyuntores, el control de colas y un bucle de agentes limitado podrían contener el fallo.

Práctica: Crear un plan de resiliencia y de costos.

- Identifique cinco dependencias y cómo puede fallar cada una.
- Defina el comportamiento de tiempo de espera, reintento, reserva y modo seguro.
- Establezca límites para usuarios, agentes, aplicaciones y suscripciones.
- Cree alertas de costos y confiabilidad.
- Planifique una prueba de fallos controlados.

Verificación de controles del capítulo

- ☐ Se documentan las dependencias y los modos de fallo.
- ☐ Los reintentos, las alternativas y las acciones repetidas son seguras.
- ☐ Existen límites de costos en varios niveles.
- ☐ Los controles de seguridad permanecen activos durante los eventos de rendimiento y recuperación.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 23: IA responsable, supervisión humana y cambio organizacional.

Proteja a las personas y las decisiones empresariales diseñando mecanismos de rendición de cuentas, transparencia, accesibilidad y un control humano significativo.

Aplicar principios de IA responsables

La equidad, la fiabilidad y la seguridad, la privacidad y la protección, la inclusión, la transparencia y la rendición de cuentas deben convertirse en requisitos verificables. Un principio resulta útil cuando modifica las decisiones de diseño, datos, evaluación, implementación o supervisión.

- Identificar a las personas afectadas y los posibles daños.
- Evaluar el desempeño en los grupos pertinentes.
- Proporcionar limitaciones comprensibles
- Diseñar interacciones y alternativas accesibles.
- Asigne responsables de la toma de decisiones
- Documentar cómo se pueden plantear y corregir las inquietudes.

Hacer que la supervisión humana sea significativa

La revisión humana resulta ineficaz cuando el revisor carece de tiempo, información, autoridad o una forma viable de expresar su desacuerdo. Es fundamental definir qué decisiones requieren revisión, qué evidencias considera el revisor, cómo se demuestra la incertidumbre y cómo puede detener o revertir una acción.

- Evite la aprobación automática
- Mostrar fuentes, intervalos de confianza y supuestos importantes.
- Evaluadores de trenes sobre las limitaciones del modelo
- Registro de decisiones y anulaciones
- Proteger a los revisores de la presión de producción que anula el control.

Gestionar el sesgo de automatización

La gente suele confiar en los resultados automatizados que les resultan fiables. Se requiere verificación para decisiones legales, laborales, de salud, seguridad, financieras, de identidad y de seguridad. Se debe medir si los usuarios detectan errores y proporcionar vías claras para escalarlos.

- Utilice un lenguaje ponderado en lugar de una falsa certeza.
- Mostrar citas que los usuarios pueden abrir
- Introducir fricción antes de las acciones consecuentes
- Resultados de la muestra y la revisión
- Proporcionar una ruta sin IA cuando sea necesario.

Apoyar la adopción y los canales de reporte

Cree guías sencillas, capacitación específica para cada rol, ejemplos aprobados, usos prohibidos y un sistema fácil para reportar incidentes. Fomente la notificación temprana de errores sin considerar automáticamente cada error como una falta grave.

- Enseñe a los usuarios cómo proteger los datos confidenciales.
- Explica cómo verificar el contenido generado.
- Publicar servicios aprobados
- Proporcionar a los gerentes vías de escalamiento y manejo de excepciones.
- Utilice las lecciones aprendidas de los informes para mejorar el diseño y la capacitación.

HUMANO EN EL BUCLE, SOLO DE NOMBRE

Un revisor recibe cientos de aprobaciones generadas por IA cada hora y no ve ninguna evidencia que las respalde. El sistema registra un clic humano, pero la persona no puede ejercer una supervisión efectiva.

Práctica: Diseñar un control de supervisión

- Elija una decisión trascendental con la ayuda de la IA.
- Defina qué puede recomendar la IA y qué es lo que nunca decidirá.
- Especifique las pruebas y la incertidumbre mostradas al revisor.
- Cree vías de anulación, apelación y escalamiento.
- Compruebe si un revisor puede detectar tres errores predefinidos.

Verificación de controles del capítulo

- ☐ Los principios de la IA responsable se convierten en requisitos medibles.

- ☐ Los revisores humanos tienen tiempo, pruebas, autoridad y alternativas.
- ☐ Los resultados de alto impacto se verifican de forma independiente.
- ☐ Los usuarios pueden informar, corregir, apelar y elegir una vía alternativa sin IA cuando sea necesario.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 24 — Consideraciones legales, reglamentarias, de propiedad intelectual y sobre registros

Reconocer cuándo las decisiones de ingeniería crean obligaciones en materia de privacidad, empleo, consumo, derechos de autor, contratos, sector o registros.

Incorpore la revisión legal en el proceso de admisión.

Los requisitos dependen de la jurisdicción, el sector, los datos, las personas afectadas y el uso. Los ingenieros de seguridad no deben brindar asesoramiento legal, pero sí deben identificar los factores desencadenantes con anticipación y proporcionar información precisa del sistema a los equipos legales y de privacidad.

- Datos personales y sensibles
- Empleo, crédito, seguros, salud, educación, seguridad y usos gubernamentales
- Niños y grupos vulnerables
- Información biométrica, de ubicación, de comunicación y de comportamiento
- Procesamiento transfronterizo y residencia de datos
- Decisiones automatizadas o de alto impacto

Abordar la propiedad intelectual

Revisar los derechos de capacitación, recuperación, evaluación y contenido generado. Registrar las licencias de modelos, código, conjuntos de datos, documentos, imágenes y componentes de código abierto. Evitar que los usuarios asuman que el resultado generado es automáticamente original, preciso o seguro para su publicación.

- Respete las licencias de origen y modelo.
- Controlar la ingesta de material protegido por derechos de autor y confidencial.
- Proporcione la cita y la atribución cuando sea necesario.
- Revise el código y el contenido generados antes de usarlos.
- Establecer normas para el contenido de clientes y empleados.

Conservar los registros y las pruebas

Los prompts, respuestas, aprobaciones, versiones de modelos, evaluaciones y acciones de los agentes pueden convertirse en registros comerciales o regulatorios. Coordine la retención, las retenciones legales, el descubrimiento electrónico, la privacidad, la investigación y la minimización. Conservar todo indefinidamente genera riesgos; eliminarlo todo de inmediato anula la responsabilidad.

- Clasificar los registros por propósito
- Configurar retención y acceso
- Proteger las reservas legales
- Mantener la cadena de custodia en las investigaciones.
- Eliminación de documentos y excepciones

Dar seguimiento a los requisitos cambiantes

Mantenga un registro reglamentario y designe a un propietario. Asigne las obligaciones a los controles y la evidencia, revise los cambios y evite alegar cumplimiento basándose únicamente en una característica del proveedor. Las leyes y normas pueden variar según la región y el uso.

- Responsable de la aplicabilidad e interpretación del registro
- Seguimiento de la implementación y evidencia
- Revisar contratos y subcontratistas
- Actualizar las evaluaciones después de un cambio sustancial
- Comunica tus limitaciones con honestidad.

UN CONJUNTO DE DATOS TÉCNICAMENTE SEGURO PERO NO AUTORIZADO

Un equipo protege un conjunto de datos de entrenamiento con cifrado y control de acceso, pero nunca confirma que la organización tenga derecho a usar los datos para el desarrollo de modelos. Los controles de seguridad no generan autorización legal.

Práctica: Crear una lista de activadores de requisitos

- Seleccione un caso de uso de IA para atención al cliente.
- Identificar los datos, las personas, las jurisdicciones, las decisiones, los contratos y los derechos de contenido involucrados.
- Enumere las preguntas para los equipos legales, de privacidad, de gestión de registros y de adquisiciones.
- Se necesitan evidencias de ingeniería cartográfica para responderlas.
- Defina los eventos que requieren una reevaluación.

Verificación de controles del capítulo

- ☐ La revisión legal y de privacidad comienza durante la admisión.
- ☐ Los derechos de datos y contenido están verificados.
- ☐ La retención de registros equilibra la rendición de cuentas y la minimización.

- ☐ Las afirmaciones de cumplimiento están respaldadas por los controles y las pruebas aplicables.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 25 — Marcos de referencia: NIST, ISO, MITRE y mapeo de controles

Utilice marcos de trabajo complementarios sin convertir la implementación en un mero trámite burocrático.

NIST AI RMF

El Marco de Gestión de Riesgos de IA del NIST organiza el trabajo mediante las fases de Gobernar, Mapear, Medir y Gestionar. Úselo para establecer responsabilidades, comprender el contexto y los daños, evaluar el riesgo y aplicar controles. El Perfil de IA Generativa añade riesgos y acciones específicas para la IA generativa.

- Gobernar: políticas, funciones, cultura, supervisión y rendición de cuentas.
- Mapa: contexto, usuarios, impactos, dependencias y riesgo
- Medición: pruebas, métricas, incertidumbre y seguimiento
- Gestionar: priorizar, responder, comunicar y mejorar.

Sistemas de gestión ISO y guía de riesgos

La norma ISO/IEC 42001 proporciona una estructura para el sistema de gestión de la IA. La norma ISO/IEC 27001 aborda la gestión de la seguridad de la información, la ISO/IEC 27701 la gestión de la privacidad de la información y la ISO/IEC 23894 ofrece orientación sobre los riesgos de la IA. Para trabajos formales de conformidad o certificación, utilice las normas oficiales y una interpretación cualificada.

- Definir el alcance y las partes interesadas
- Establecer políticas, objetivos, roles, competencias y procesos documentados.
- Evaluar riesgos e impactos
- Controlar el funcionamiento y conservar las pruebas.
- Auditar, corregir, revisar y mejorar continuamente.

Ciberseguridad y marcos de trabajo adversarios

El Marco de Ciberseguridad 2.0 del NIST organiza los resultados de ciberseguridad en las fases de Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar. La norma NIST SP 800-53 permite la selección detallada de controles. Las normas NIST SSDF y SP 800-218A facilitan el desarrollo seguro. MITRE ATLAS cataloga las tácticas y técnicas de la IA adversaria.

- Utilice CSF para los resultados del programa
- Utilice catálogos de control para conocer los requisitos detallados.
- Utilice SSDF para el ciclo de vida del desarrollo.

- Utilice ATLAS y OWASP para detectar amenazas y realizar pruebas.
- Evite duplicar la evidencia asignando un control a varios requisitos.

Crear un mapeo cruzado útil

Comience con los controles implementados y la evidencia, luego relaciónelos con los resultados del marco. No cree controles separados para cada etiqueta del marco cuando un control bien diseñado satisface varias necesidades. Registre honestamente las brechas y las diferencias.

- Objetivo y descripción del control
- Propietario y alcance
- Ubicación de implementación
- Método y frecuencia de la prueba
- Evidencia y retención
- Requisitos mapeados
- Excepciones y medidas correctivas

CUMPLE CON LAS NORMAS EN UNA HOJA DE CÁLCULO, PERO DEFICIENTE EN LA PRODUCCIÓN.

Una matriz de control indica que las revisiones de acceso se han completado porque existe una política. Los permisos del responsable del servicio nunca se han examinado. La elaboración de un mapa del marco sin evidencia operativa genera una falsa sensación de seguridad.

Práctica: Mapear un control en distintos marcos

- Seleccionar revisión trimestral de las identidades de los agentes y la carga de trabajo.
- Defina el objetivo, el alcance, el responsable, el método, las pruebas y el manejo de fallos.
- Relaciónelo con los resultados de NIST AI RMF, NIST CSF, ISO/IEC 42001, ISO/IEC 27001 y OWASP NHI.
- Identifique cualquier deficiencia específica del marco de trabajo.
- Cree un registro de prueba.

Verificación de controles del capítulo

- ☐ Los marcos de trabajo se utilizan para el propósito para el que fueron diseñados.
- ☐ Los mapeos apuntan a la implementación real y a la evidencia.
- ☐ Un control sólido puede respaldar varios marcos de trabajo.
- ☐ La certificación formal se basa en estándares oficiales y una evaluación cualificada.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 26 — Creación de un programa de gobernanza y aseguramiento de la IA

Crear un sistema operativo para la toma de decisiones mediante IA, la gestión de inventarios, la aceptación de riesgos, el monitoreo, las excepciones y la mejora continua.

Establecer la gobernanza

Cree un grupo multifuncional con representación de las áreas de negocio, tecnología, seguridad, privacidad, legal, cumplimiento normativo, riesgos, datos, compras, recursos humanos y seguridad, según corresponda. Defina los derechos de decisión para que el grupo permita un uso responsable y oportuno, en lugar de convertirse en una cola de revisión poco clara.

- Aprobar la política y la clasificación de riesgos.
- Establecer usos prohibidos y restringidos
- Definir las evidencias y los puntos de liberación
- Asignar la escalación y la aceptación del riesgo.
- Revisar incidentes, métricas, excepciones y cambios importantes.

Mantener un Inventario de sistemas de IA

Inventario de IA de desarrollo interno, adquirida, integrada, experimental y en la sombra. Registrar propósito, propietario, usuarios, personas afectadas, modelo, proveedor, datos, agentes, NHI, integraciones, región, nivel de riesgo, aprobaciones, monitoreo, incidentes, fecha de revisión y estado de retiro.

- Descubra a través de señales de adquisiciones, nube, identidad, red, endpoint y datos.
- Conciliar el inventario con las fuentes técnicas.
- Se requiere registro antes de la producción.
- Revisar los sistemas inactivos y de alto riesgo.
- Los registros de jubilación solo se eliminarán después de que se hayan retirado los activos vinculados.

Aplicar aseguramiento por niveles de riesgo

La elaboración de documentos de bajo riesgo no debería requerir la misma evidencia que un sistema autónomo que afecte el empleo o la seguridad. Defina los niveles utilizando el impacto, la autonomía, la sensibilidad de los datos, la escala, la exposición externa, la reversibilidad y las poblaciones afectadas. Aumente la revisión y el monitoreo a medida que aumenta el riesgo.

- Criterios de nivelación del documento
- Establecer controles mínimos por nivel

- Permitir la escalada cuando la incertidumbre es alta
- Requerir revisión independiente para usos de alto impacto.
- Reevaluar después de un cambio importante

Medir el estado del programa

Utilice un conjunto equilibrado de indicadores: cobertura de inventario, tiempo de revisión, acciones vencidas, excepciones de alto riesgo, hallazgos de identidad, exposición de datos, fallos de evaluación, incidentes, tiempo de contención, cambios de modelo, capacitación, anomalías de costos y finalización de la jubilación.

- Evite las métricas que premian la ocultación de incidentes.
- Informe sobre tendencias y riesgos materiales
- Vincular los hallazgos con los propietarios y los plazos de entrega.
- Analizar si los controles reducen el daño.
- Mejorar las políticas y los estándares de ingeniería después de la evidencia

EL INVENTARIO CONTIENE ÚNICAMENTE SISTEMAS APROBADOS.

Los informes de gobernanza ofrecen una cobertura completa, ya que se revisa cada aplicación registrada. Los datos de red y gastos revelan que los empleados utilizan decenas de servicios de IA no registrados. La calidad del inventario debe medirse comparándola con las fuentes de detección.

Práctica: Diseñar un flujo de trabajo de gobernanza

- Cree campos de admisión y criterios de nivel de riesgo.
- Defina los revisores, los derechos de decisión, los objetivos del servicio y el procedimiento de escalamiento.
- Enumere las pruebas necesarias para los niveles de riesgo bajo, medio y alto.
- Cree flujos de trabajo para cambios, excepciones, incidentes y bajas.
- Seleccione diez indicadores del programa que fomenten la presentación de informes honestos.

Verificación de controles del capítulo

- ☐ Los derechos de decisión y la aceptación del riesgo son claros.
- ☐ El inventario incluye IA comprada, integrada, experimental y en la sombra.
- ☐ El esfuerzo de aseguramiento aumenta en proporción al riesgo.
- ☐ Las métricas miden la cobertura, los resultados, la respuesta y la mejora.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

PARTE V — LABORATORIOS PRÁCTICOS

Transformar conceptos en prácticas de ingeniería repetibles.

COMPRENDER • APLICAR • PROBAR • DEMOSTRAR

Capítulo 27 — Laboratorios guiados de ingeniería de seguridad

Practique el flujo de trabajo completo en entornos seguros y autorizados, utilizando datos de bajo riesgo y objetivos controlados.

Normas del laboratorio

Utilice únicamente recursos de su propiedad o para los que tenga autorización explícita para realizar pruebas. Comience con datos sintéticos. Establezca presupuestos y fechas de finalización. Nunca dirija pruebas automatizadas a sistemas públicos o de producción sin autorización por escrito, alcance aprobado, supervisión y condiciones de detención.

- Objetivo del documento, propietario, alcance, cuentas, recursos y tráfico previsto
- Cree instantáneas o plantillas reproducibles.
- Utilice identidades de prueba separadas
- Proteja los resultados de la prueba
- Limpiar endpoints, índices, secretos, identidades, registros y datos.

Laboratorios de fundamentos

Los primeros laboratorios establecen una estructura segura de múltiples cuentas de AWS, la identidad, la clasificación de datos y el registro de eventos. Complételos antes de que el agente o el equipo rojo realicen pruebas.

- Crear un diseño de nombres de entorno y recursos
- Construir una matriz de roles de mínimo privilegio
- Configure un rol de IAM y acceso a Secrets Manager o AWS KMS.
- Diseñar rutas de servicio privadas
- Envíe CloudTrail, CloudWatch, VPC Flow Logs y registros de servicios a cuentas centrales de seguridad.
- Crear alertas de presupuesto y cuota

Laboratorios de aplicaciones de IA

Cree un pequeño asistente de políticas con documentos aprobados, citas, recuperación con permisos, controles de contenido y solicitudes rastreables. Agregue funciones una por una y vuelve a probar después de cada cambio.

- Implemente o seleccione un modelo aprobado.
- Create a versioned system instruction

- Construir un corpus RAG protegido
- Prueba de respuestas desconocidas y citas
- Agregar una herramienta de solo lectura restringida
- Crear una identidad de agente y un bucle delimitado

Laboratorios de aseguramiento y operaciones

Pruebe la aplicación finalizada utilizando modelos de amenazas, casos OWASP, análisis de vulnerabilidades RAG, revisión de NHI, pruebas de penetración (red teaming), respuesta a incidentes y mapeo de marcos de trabajo.

- Ejecutar conjuntos de datos de evaluación y regresión
- Ejercicio de inyección rápida directa e indirecta
- Revisión de la autorización y el aislamiento entre usuarios
- Simular credenciales comprometidas y costos descontrolados
- Realizar un simulacro de incidente
- Recopile un paquete de evidencia de auditoría

UN LABORATORIO SIN LIMPIEZA

El alumno completa un ejercicio de agente seguro, pero deja activos un despliegue modelo, un servicio de búsqueda, un endpoint de prueba público y un secreto de aplicación. La limpieza forma parte del laboratorio, no es una nota final opcional.

Práctica: Preparar el plan de laboratorio

- Indique el objetivo de aprendizaje y la autorización.
- Enumere los recursos, las identidades, los datos, las regiones, los límites y el costo previsto.
- Defina las condiciones de detención y el manejo de las pruebas.
- Programar la limpieza y la verificación.
- Pida a una segunda persona que revise las pruebas de alto impacto.

Verificación de controles del capítulo

- ☐ Los laboratorios utilizan objetivos propios o autorizados explícitamente.
- ☐ Los datos sintéticos o de bajo riesgo son la opción predeterminada.
- ☐ Se definen las condiciones de costo, tráfico y parada.
- ☐ La limpieza incluye identidades, datos, índices, endpoints, secretos y registros.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

Capítulo 28 — Proyecto final: Agente de conocimiento empresarial seguro

Reúna la arquitectura, la identidad, la gestión de riesgos, los controles de agentes, las pruebas, la gobernanza y las operaciones en un único proyecto basado en evidencia.

Objetivo empresarial

Diseñe un agente de conocimiento interno que responda preguntas aprobadas sobre políticas de ciberseguridad, cite fuentes, abra un ticket de servicio mediante una herramienta específica y rechace solicitudes no autorizadas o sin soporte. Utilice documentos sintéticos que representen clasificaciones públicas, internas y restringidas.

- Defina los usuarios previstos y los usos prohibidos.
- Establecer resultados medibles en cuanto a calidad, seguridad, privacidad, protección, fiabilidad y costos.
- Asignar responsables de negocio, datos, ingeniería, seguridad, privacidad y operaciones.
- Clasifique el caso de uso y obtenga la aprobación.

Arquitectura y construcción

Cree diseños de desarrollo y producción independientes utilizando Amazon Bedrock o SageMaker AI, un modelo aprobado, Bedrock Knowledge Bases u OpenSearch, Amazon S3, roles de IAM, Secrets Manager y KMS, API Gateway, resultados de Macie y DataZone, Security Hub, GuardDuty y monitoreo centralizado. Conserve los permisos de los documentos durante la recuperación.

- Dibujar flujos de datos y control
- Límites de confianza del modelo de amenazas
- Utilice identidades administradas
- Restringir la red y la salida
- Código de versión, prompts, datos, índice, evaluación e implementación
- Se requiere confirmación humana antes de enviar el ticket si este cambia de servicio o acceso.

Aseguramiento

Evaluar preguntas normales, preguntas desconocidas, fuentes contradictorias, contenido obsoleto, inyección de prompts directa e indirecta, divulgación sensible, recuperación entre usuarios, mal uso de la herramienta, solicitudes excesivas, contenido dañino y fallas del proveedor. Convertir los hallazgos confirmados en pruebas de regresión.

- Establecer fallos que bloquean la liberación
- Realizar una revisión por pares y un equipo rojo autorizado.
- Revisión de los sistemas nacionales de salud y sus secretos
- Confirmar los manuales de registro y de incidentes.
- Registro del riesgo residual y aceptación

Operaciones y evidencia

Cree paneles de control, alertas, presupuestos, revisiones de acceso, cronogramas de evaluación, puntos de cambio, manuales de incidentes, procedimientos de respaldo y recuperación, y pasos para la eliminación de software obsoleto. Prepare un paquete que otro ingeniero o auditor pueda seguir sin necesidad de explicaciones orales.

- Arquitectura y modelo de amenazas
- Inventario y lista de materiales de IA
- Registros de datos e identidad
- Informes de evaluación y de equipos rojos
- Matriz de control y aprobaciones
- Procedimientos de operaciones, incidentes, recuperación y retiro

LA DECISIÓN DE LANZAMIENTO DE LA PIEDRA FINAL

El agente cumple con los objetivos de calidad y coste, pero falla en una prueba de autorización entre usuarios. La decisión correcta es bloquear el lanzamiento, corregir el diseño del filtrado, volver a ejecutar el conjunto completo de pruebas pertinentes y documentar el resultado.

Práctica: Completar el proyecto final

- Crear el acta constitutiva y la arquitectura del proyecto.
- Construya el sistema mínimo funcional.
- Implementar controles de identidad, datos, red, aplicación, modelo y monitoreo.
- Realizar ejercicios de evaluación, de equipo rojo, de resiliencia y de incidentes.
- Presentar evidencia, riesgo residual y una recomendación de liberación.

Verificación de controles del capítulo

- ☐ La piedra angular es útil, delimitada, autorizada y medible.
- ☐ Los permisos se aplican antes de la recuperación y la ejecución de la herramienta.
- ☐ Los fallos críticos bloquean la liberación.

- ☐ La evidencia respalda la construcción, prueba, operación, respuesta y retiro.

PRUEBAS PARA CONSERVAR

Actualizaciones de arquitectura o flujo de datos, evidencia de configuración o políticas, resultados de pruebas, hallazgos y soluciones, aprobaciones, excepciones y la fecha y el responsable de la próxima revisión.

APÉNDICES

Listas de verificación reutilizables, plantillas, glosario y fuentes de aprendizaje oficiales.

COMPRENDER • APLICAR • PROBAR • DEMOSTRAR

Apéndice A — Lista de verificación de preparación para la producción

Propósito y propiedad

- ☐ Finalidad aprobada y usos prohibidos
- ☐ Propietarios de negocios, datos, ingeniería, seguridad, privacidad y operaciones
- ☐ Nivel de riesgo y autoridad de aceptación
- ☐ Supervisión humana y vía de apelación

Arquitectura e identidad

- ☐ Diagrama actual de flujo de datos y límites de confianza
- ☐ Identidades de usuario, carga de trabajo y agente con privilegios mínimos
- ☐ Identidad gestionada o federación cuando sea práctico
- ☐ Controles de red privados y salientes
- ☐ Secrets Manager, KMS y evidencia de rotación

Datos y RAG

- ☐ Fuentes aprobadas, clasificaciones, permisos, linaje y retención
- ☐ Filtrado de permisos antes de la recuperación
- ☐ Pruebas de intoxicación e inyección indirecta
- ☐ Prueba de eliminación de datos derivados
- ☐ Citación y comportamiento de respuesta desconocida

Agentes y herramientas

- ☐ Inventario aprobado de agentes, servidores MCP, conectores y herramientas
- ☐ Objetivos, pasos, tiempo, costo, destinos y transacciones con límites definidos.
- ☐ Validación de la entrada y salida de la herramienta
- ☐ Aprobación humana para acciones con consecuencias
- ☐ Procedimiento de desactivación de emergencia

Aseguramiento y operaciones

- ☐ Evaluaciones de calidad, seguridad, privacidad, fiabilidad y costos
- ☐ Informe y remediación autorizados del equipo rojo

- ☐ Registros y alertas de extremo a extremo
- ☐ Manuales de incidentes, interrupciones, costos y proveedores
- ☐ Pruebas de retroceso, recuperación y retirada

Apéndice B — Plantilla de admisión de casos de uso de IA

Nombre del caso de uso y objetivo comercial

Respuesta: _____

Patrocinador ejecutivo y propietario del negocio

Respuesta: _____

Usuarios previstos y personas afectadas

Respuesta: _____

Usos previstos y prohibidos

Respuesta: _____

Decisiones o acciones respaldadas

Respuesta: _____

Modelos, proveedores, regiones y ruta de implementación

Respuesta: _____

Fuentes de datos, clasificaciones, propietarios y finalidad permitida

Respuesta: _____

RAG, memoria, agentes, servidores MCP, herramientas y conexiones externas

Respuesta: _____

Supervisión humana, apelación, corrección y alternativa no basada en IA

Respuesta: _____

Daños potenciales y mayor impacto creíble

Respuesta: _____

Revisión legal, de privacidad, de registros, contractual y del sector

Respuesta: _____

Medidas de calidad, seguridad, protección, privacidad, fiabilidad y costos

Respuesta: _____

Nivel de riesgo, revisores necesarios, aprobación y fecha de la próxima revisión.

Respuesta: _____

Apéndice C — Campos del inventario de sistemas de IA y NHI

Inventario de sistemas de IA

- ID del sistema, nombre, descripción y estado
- Propietario del negocio, responsable técnico, responsable de los datos y patrocinador.
- Usuarios, personas afectadas, escala y geografía
- Nivel de riesgo y registro de aprobación
- Modelos, proveedores, versiones, ruta de implementación y región
- Fuentes de datos, clasificación, retención y eliminación
- RAG, memoria, agentes, herramientas, MCP, API y conectores
- Arquitectura de seguridad, monitoreo, incidentes, excepciones y próxima revisión.
- Fecha de jubilación y confirmación de la retirada del recurso

Inventario de identidades no humanas

- ID de identidad, tipo, tenant, entorno y método de creación
- Propietario, patrocinador, propósito y sistema dependiente
- Roles, ámbitos de API, recursos y autoridad delegada
- Tipo de credencial, ubicación, rotación y vencimiento
- Último inicio de sesión, actividad reciente, eventos de riesgo y fecha de revisión.
- Activador de desvinculación, método de desactivación y contacto de emergencia

Apéndice D — Plantilla de riesgo y hallazgo

- Título
- Sistema y componente afectado
- Escenario y condiciones previas
- Amenaza o fracaso
- Debilidad o brecha de control
- Impacto en el negocio, la tecnología, la privacidad o la seguridad
- Pasos para la obtención de pruebas y la reproducción
- Probabilidad y calificación de impacto
- Requisitos aplicables de OWASP, MITRE, NIST, ISO o internos.
- Medidas recomendadas y controles compensatorios
- Propietario, fecha de vencimiento y estado
- Resultado de la nueva prueba
- Riesgo residual y autoridad de aceptación

CONSEJO DE ESCRITURA

Expresa lo observado, lo inferido y lo que podría suceder como ideas separadas. Los hallazgos claros son más fáciles de verificar y de poner en práctica.

Apéndice E — Glosario

Término	Significado
Agente	Software que utiliza un modelo para planificar o seleccionar acciones, a menudo mediante herramientas u otros servicios.
Identidad del agente	Una identidad controlada que representa a un agente de IA y su acceso permitido.
Lista de materiales de IA	Un inventario de modelos, datos, código, prompts, herramientas, servicios y dependencias utilizados por un sistema de IA.
sistema de IA	La combinación completa de modelo, aplicación, datos, personas, procesos, identidades, herramientas e infraestructura.
API	Una interfaz definida que permite a los servicios de software intercambiar solicitudes y resultados.
Autenticación	El proceso de probar una identidad.
Autorización	La decisión sobre qué puede hacer una identidad autenticada.
Pedazo	Una parte de un documento preparada para su búsqueda, inserción o recuperación.
Confidencialidad	Protección contra la divulgación no autorizada.
Filtro de contenido	Un control que detecta o bloquea categorías configuradas de entrada o salida.
Ventana de contexto	La cantidad limitada de instrucciones e información disponibles para un modelo durante una solicitud.
Control	Una medida de protección que modifica la probabilidad o el impacto del riesgo.
Linaje de datos	Un registro de dónde provienen los datos, cómo cambiaron y adónde se movieron.

Término	Significado
Envenenamiento de datos	Manipulación de datos de entrenamiento, evaluación, recuperación u otros datos para influir en el comportamiento del sistema.
Embedding	Una representación numérica utilizada para comparar significados o similitudes.
Fine-tuning	Se utiliza un entrenamiento adicional del modelo para ajustar el comportamiento a los ejemplos o a una tarea específica.
Grounding	El grado en que una respuesta está respaldada por la información de la fuente proporcionada.
Guardrail	Una política, filtro, límite, validación, aprobación u otra restricción sobre el comportamiento del sistema.
Alucinación	Contenido generado que parece plausible pero que carece de fundamento o es incorrecto.
Supervisión humana	Capacidad humana significativa para revisar, detener, corregir o revertir una acción respaldada por IA.
Inferencia	Utilizar un modelo entrenado para producir un resultado.
Integridad	Protección contra cambios no autorizados o indebidos.
Menor privilegio	Proporcionar únicamente el acceso necesario para una tarea y un tiempo definidos.
Máster en Derecho	Un modelo lingüístico de gran tamaño entrenado para procesar y generar lenguaje.
LLMOps	Prácticas para el versionado, la publicación, la monitoreo y la retirada de aplicaciones basadas en modelos de lenguaje.
Identidad gestionada	Una identidad administrada por Azure que las aplicaciones pueden usar sin almacenar credenciales ordinarias.
MCP	Model Context Protocol, un estándar utilizado para conectar aplicaciones de modelos con herramientas y contexto.

Término	Significado
Filtrado de metadatos	Utilizar atributos como usuario, tenant, clasificación o fuente para restringir la recuperación.
Model Card	Una descripción del uso previsto del modelo, su evaluación, sus limitaciones y otra información importante.
Identidad no humana	Una identidad utilizada por software, automatización, cargas de trabajo, agentes o dispositivos, en lugar de una persona.
Prompt	Texto u otra información proporcionada para guiar la respuesta del modelo.
Inyección de prompts	Entrada que intenta alterar el comportamiento del modelo o anular las instrucciones previstas.
RAG	Generación aumentada mediante recuperación, que proporciona la información recuperada a un modelo en el momento de la solicitud.
Red Teaming	Pruebas autorizadas que simulan el mal uso, el ataque o la imposibilidad de identificar riesgos.
Riesgo residual	El riesgo persiste incluso después de aplicar las medidas de control.
Propietario del riesgo	La persona responsable del objetivo empresarial afectado y de la decisión sobre el riesgo.
Security trimming	Filtrar los resultados de búsqueda o recuperación para que una identidad reciba únicamente contenido autorizado.
Service principal	Una identidad utilizada por una aplicación o servicio en Microsoft Entra ID.
Shadow AI	Servicios o capacidades de IA utilizados sin la aprobación o visibilidad organizativa requerida.
System instruction	La aplicación proporciona orientación destinada a moldear el comportamiento del modelo.
Token	Una unidad de texto procesada por un modelo de lenguaje.
Tool call	Solicitud estructurada de una aplicación o un modelo para que un software externo realice una operación.

Término	Significado
Límite de confianza (trust boundary)	Un punto donde los datos o el control atraviesan diferentes niveles de confianza o autoridad.
Base de datos vectorial	Un servicio que almacena y busca elementos incrustados y metadatos asociados.
Identidad de carga de trabajo	Una identidad utilizada por una aplicación, servicio, contenedor o carga de trabajo de automatización.
Confianza cero	Un enfoque de seguridad basado en la verificación explícita, el principio de mínimo privilegio y la suposición de compromiso.

Apéndice F — Fuentes oficiales y formación continua

Utilice fuentes oficiales actualizadas al implementar controles o tomar decisiones sobre el cumplimiento normativo. Las páginas de productos, las normas, las leyes, las características y la disponibilidad de los modelos pueden cambiar.

PRINCIPIO DE CIERRE

Un buen ingeniero de seguridad mantiene la curiosidad, verifica las suposiciones, documenta las pruebas, protege a las personas y mejora el sistema después de cada cambio y lección aprendida.

[Documentación de Amazon Bedrock](#)

[Documentación de Amazon SageMaker AI](#)

[Arquitectura de referencia de seguridad de AWS para IA](#)

[Documentación de AWS Identity and Access Management](#)

[Documentación de IAM Identity Center](#)

[AWS Security Hub CSPM y GuardDuty](#)

[AWS Well-Architected Generative AI Lens](#)

[Amazon Bedrock Guardrails](#)

[AWS Responsible AI Lens](#)

[OWASP Top 10 para aplicaciones LLM](#)

[OWASP Top 10 para aplicaciones agentic](#)

[OWASP Top 10 para identidades no humanas \(NHI\)](#)

[OWASP API Security](#)

[MITRE ATLAS](#)

[NIST AI Risk Management Framework \(AI RMF\)](#)

[NIST Generative AI Profile](#)

[NIST Secure Software Development Framework \(SSDF\)](#)

[NIST Cybersecurity Framework \(CSF\)](#)

[OpenAI API Documentation](#)

[OpenAI File Search](#)

[Anthropic Claude Documentation](#)

[ISO/IEC 42001 Overview](#)

Registro de mantenimiento

Revise este manual al menos cada seis meses y después de cambios importantes en Amazon Bedrock, SageMaker AI, IAM, Macie o Security Hub, proveedores de modelos, directrices de OWASP, publicaciones del NIST o legislación aplicable. Registre las correcciones y las notas de la versión en el repositorio de publicaciones.